

OPERATIONAL CYBER RISK ASSESSMENT

Montevideo Shopping

Evaluación de Riesgos de Ciberseguridad y Resiliencia Operativa

Caso de Estudio Independiente

Francisco Noya

Julio 2026

Documento elaborado con fines académicos y profesionales.
No constituye una auditoría oficial ni una evaluación autorizada por la organización.

ÍNDICE

1. Resumen Ejecutivo	2
2. Descripción de la Organización	5
2.1 Introducción	6
2.2 Perfil Organizacional	6
2.3 Infraestructura	8
2.4 Áreas Organizacionales	9
2.5 Servicios Críticos	10
2.6 Dependencias Operativas	10
2.7 Infraestructura Tecnológica	11
2.8 Contexto de Riesgo	12
3. Alcance del Assessment	12
3.1 Objetivo del Assessment	12
3.2 Activos Incluidos	13
3.3 Infraestructura Considerada	14
3.4 Exclusiones	17
3.5 Consideraciones del Assessment	18
4. Metodología	18
4.1 Introducción	18
4.2 Marcos de Referencia	19
4.3 Proceso Metodológico	19
4.4 Identificación de Activos	20
4.5 Identificación de Amenazas	20
4.6 Identificación de Vulnerabilidades	21
4.7 Evaluación del Riesgo	21
4.8 Escala de Probabilidad	22
4.9 Escala de Impacto	22
4.10 Matriz de Evaluación del Riesgo	23
4.11 Tratamiento del Riesgo	23
4.12 Conclusiones de la Metodología	24
5. Inventario y Clasificación de Activos	24
5.1 Objetivo	24
5.2 Metodología de Clasificación	25
5.3 Modelo CIA	26
5.4 Escala de Clasificación CIA	28
5.5 Criterios de Criticidad	28

5.6 Clasificación General de Activos	28
5.7 Relación entre Activos y Gestión de Riesgos	29
5.8 Inventario de Activos Físicos	29
5.9 Registro de Activos Físicos	30
5.10 Clasificación por Nivel de Criticidad	32
5.11 Análisis del Inventario Físico	33
5.12 Recomendaciones Generales	34
5.13 Inventario de Activos Tecnológicos	34
5.14 Registro de Activos Tecnológicos	35
5.15 Clasificación por Criticidad	38
5.16 Análisis del Inventario Tecnológico	40
5.17 Recomendaciones Generales	40
5.18 Inventario de Activos de Información	41
5.19 Inventario de Activos Humanos	42
5.20 Inventario de Servicios Críticos	43
5.21 Inventario de Proveedores Críticos	44
5.22 Resumen General de Activos	45
5.23 Distribución por Nivel de Criticidad	46
5.24 Principales Observaciones	46
5.25 Conclusiones	47
6. Identificación de Amenazas	47
6.1 Introducción	47
6.2 Clasificación General de Amenazas	48
6.3 Amenazas Humanas	48
6.4 Amenazas Tecnológicas	50
6.5 Amenazas Operacionales	52
6.6 Amenazas Ambientales	54
6.7 Amenazas Físicas	55
6.8 Matriz Resumen de Amenazas	56
6.9 Observaciones Generales	56
6.10 Conclusiones	56
7. Identificación de Vulnerabilidades (Gap Analysis)	56
7.1 Introducción	57
7.2 Objetivo del Gap Analysis	57
7.3 Criterios de Evaluación	57
7.4 Registro de Vulnerabilidades (Gap Analysis)	58
7.5 Clasificación por Dominio	60
7.6 Distribución de Vulnerabilidades	61
7.7 Principales Brechas Identificadas	62
7.8 Conclusiones	62

8. Evaluación de Riesgos	62
8.1 Introducción	62
8.2 Objetivo de la Evaluación	63
8.3 Metodología de Evaluación	63
8.4 Escala de Probabilidad	64
8.5 Escala de Impacto	64
8.6 Fórmula de Evaluación del Riesgo	65
8.7 Clasificación del Nivel de Riesgo	66
8.8 Criterios de Aceptación del Riesgo	66
8.9 Opciones de Tratamiento del Riesgo	66
8.10 Riesgo Inherente y Riesgo Residual	67
8.11 Principios Utilizados Durante la Evaluación	68
8.12 Conclusiones	68
9. Matriz de Riesgos	68
9.1 Introducción	68
9.2 Criterios de Clasificación	69
9.3 Registro de Riesgos (Risk Register)	69
9.4 Resumen Estadístico de Riesgos	71
9.5 Matriz de Riesgos (Heat Matrix)	72
9.6 Observaciones del Análisis	74
9.7 Conclusiones	74
10. Top 15 Riesgos Prioritarios	75
10.1 Conclusiones del Capítulo	105
11. Heat Map Ejecutivo	105
11.1 Introducción	105
11.2 Escala Utilizada	106
11.3 Heat Map de Riesgos	107
11.4 Distribución de Riesgos	107
11.5 Análisis Ejecutivo	108
11.6 Riesgos Prioritarios	109
11.7 Conclusiones	109
12. Roadmap de Implementación	110
12.1 Introducción	110
12.2 Fase I – Corto Plazo (0–90 días)	110
12.3 Fase II – Mediano Plazo (90–180 días)	112
12.4 Fase III – Largo Plazo (6–12 meses)	113
12.5 Resumen Ejecutivo del Roadmap	114
12.6 Beneficios Esperados	114
12.7 Conclusiones	114

13. Quick Wins – Iniciativas de Implementación Inmediata	114
13.1 Introducción	114
13.2 Quick Wins Prioritarios	115
13.3 Acciones Recomendadas	115
13.4 Beneficios Esperados	118
13.5 Resumen Ejecutivo de Quick Wins	119
13.6 Conclusiones	119
14. Conclusión General	119

1. Resumen Ejecutivo

Objetivo

El presente documento tiene como finalidad evaluar los principales riesgos de ciberseguridad y resiliencia operativa asociados a un centro comercial moderno, utilizando como caso de estudio al Montevideo Shopping.

El Assessment fue desarrollado aplicando un enfoque basado en riesgos alineado con ISO/IEC 27001:2022, ISO 31000:2018, NIST Cybersecurity Framework (CSF) 2.0 y CIS Controls v8.

El objetivo principal consiste en identificar los activos críticos, evaluar las amenazas y vulnerabilidades que podrían afectar la continuidad del negocio y proponer un plan de tratamiento orientado a reducir la exposición al riesgo y fortalecer la resiliencia organizacional.

Dado que el documento constituye un caso de estudio independiente, todas las conclusiones se basan en información pública, observación general del entorno y supuestos razonables construidos conforme a buenas prácticas internacionales.

Alcance

Este estudio comprende un análisis de alto nivel del contexto organizacional, los activos críticos, las amenazas, las vulnerabilidades y los riesgos asociados a la operación de un centro comercial, con el propósito de proponer medidas para fortalecer la seguridad de la información y la continuidad del negocio.

El análisis contempla los siguientes componentes operativos:

- Infraestructura comercial.
- Áreas administrativas.
- Infraestructura tecnológica.
- Sistemas de estacionamiento.
- Sistemas de videovigilancia.
- Infraestructura eléctrica de respaldo.
- Operaciones de atención al cliente.
- Procesos administrativos.
- Dependencia de proveedores críticos.
- Continuidad operativa.

Dentro del caso de estudio se consideran como áreas relevantes:

- Subsuelo (estacionamientos, oficinas de parking y locales comerciales).
- Nivel principal con locales comerciales, plaza de comidas, supermercado y servicios.
- Entrepiso con instituciones financieras, servicios médicos y gimnasio.

- Segundo nivel comercial y complejo de cines.
- Tercer nivel con locales comerciales.

Quedan expresamente fuera del alcance:

- Auditorías técnicas sobre infraestructura informática.
- Acceso a redes internas.
- Revisión de configuraciones de seguridad.
- Evaluación de servidores.
- Análisis de información confidencial.
- Entrevistas con colaboradores.
- Pruebas de penetración.
- Evaluaciones de cumplimiento normativo oficiales.

Este documento constituye exclusivamente un caso de estudio independiente elaborado con fines académicos y profesionales, sin representar una auditoría oficial ni una evaluación autorizada por la organización.

Datos principales del Assessment

Indicador	Valor
Activos evaluados	120
Riesgos Identificados	25
Vulnerabilidades identificadas	30
Marcos utilizados	ISO 27001 - ISO 31000 - NIST CSF - CIS v8
Nivel de análisis	Assessment GRC

Metodología

La evaluación fue desarrollada siguiendo un enfoque basado en riesgos ampliamente utilizado dentro del ámbito de la Gobernanza, Gestión de Riesgos y Cumplimiento (GRC).

La metodología utilizada durante el Assessment se desarrolló siguiendo un proceso estructurado de gestión de riesgos compuesto por siete etapas principales:

- Comprensión del contexto
- Identificación de activos
- Identificación de amenazas
- Identificación de vulnerabilidades
- Evaluación del riesgo
- Priorización
- Tratamiento del riesgo

La descripción detallada de cada una de estas etapas se presenta en el Capítulo 4 del presente documento.

Como referencia metodológica se consideraron las siguientes normas y marcos internacionales:

- ISO/IEC 27001:2022

- ISO 31000:2018
- NIST Cybersecurity Framework (CSF) 2.0
- CIS Controls v8

Resultado General

El análisis realizado evidencia que la operación de un shopping center moderno depende de una combinación compleja de infraestructura física, servicios tecnológicos, procesos administrativos y proveedores externos.

La disponibilidad de servicios como el estacionamiento, los sistemas de videovigilancia, la infraestructura eléctrica de respaldo, las redes de comunicaciones y los sistemas administrativos resulta fundamental para garantizar la continuidad del negocio.

A partir del estudio se identifican como escenarios de mayor exposición:

Hallazgos Principales

Categoría	Resultado
Activos Identificados	120 activos inventariados
Vulnerabilidades potenciales	30 vulnerabilidades identificadas
Escenarios de riesgo analizados	25 escenarios evaluados
Mayor exposición	Ransomware Phishing Dependencia de terceros Interrupcion electrica Continuidad del negocio
Marcos y estándares utilizados	ISO/IEC 27001 ISO 31000 NIST Cybersecurity Framework (CSF) 2.0 CIS Controls v8

2. Descripción de la Organización

Nota metodológica: La información presentada en este capítulo se basa en fuentes públicas y en supuestos razonables de la operación típica de un centro comercial, contruidos con fines exclusivamente académicos. No implica acceso a información interna, confidencial o no pública de Montevideo Shopping, y no debe interpretarse como una descripción verificada de su infraestructura, controles o procesos reales.

2.1 Introducción

La comprensión del contexto organizacional constituye una etapa fundamental dentro de cualquier proceso de gestión de riesgos, ya que permite identificar los elementos estratégicos que soportan la operación del negocio y establecer el alcance sobre el cual se desarrollará el análisis.

En el caso de un centro comercial, la operación diaria depende de la interacción permanente entre infraestructura física, tecnología, procesos administrativos, proveedores externos, locatarios y un elevado flujo de clientes. Esta interdependencia genera un entorno operativo complejo donde la disponibilidad de los servicios y la continuidad del negocio representan factores críticos para el éxito de la organización.

El presente capítulo describe, desde una perspectiva general y basada exclusivamente en información pública y conocimiento operativo del sector, las principales características del Montevideo Shopping, proporcionando el contexto necesario para el desarrollo del Assessment de Riesgos de Ciberseguridad y Resiliencia Operativa presentado en este documento.

2.2 Perfil Organizacional

Montevideo Shopping constituye uno de los principales centros comerciales del Uruguay, ofreciendo una amplia variedad de servicios comerciales, gastronómicos, financieros y de entretenimiento dentro de un mismo complejo.

Su modelo de negocio se basa en la administración y operación de espacios comerciales destinados a empresas locatarias, complementados por servicios orientados a mejorar la experiencia de clientes y visitantes.

Desde una perspectiva operativa, el centro comercial reúne una gran diversidad de actores que interactúan diariamente, entre ellos:

- Administración del centro comercial.
- Empresas locatarias.
- Clientes y visitantes.
- Empresas proveedoras de servicios.

- Personal propio.
- Empresas tercerizadas.
- Organismos financieros.
- Empresas de entretenimiento.
- Servicios médicos.
- Empresas de mantenimiento.

Esta diversidad convierte al shopping en una organización altamente dependiente de la coordinación entre procesos administrativos, infraestructura física y recursos tecnológicos.

Información General

Concepto	Descripción
Tipo de organización	Centro Comercial (Shopping Center)
Industria	Retail y Servicios
Ubicación	Montevideo, Uruguay
Actividad principal	Administración y operación de un centro comercial multipropósito
Público objetivo	Clientes, visitantes, empresas locatarias y proveedores
Operación	Continua durante el horario comercial

El centro comercial cuenta con aproximadamente 178 locales comerciales y recibe alrededor de 45.000 visitantes diarios.

2.3 Infraestructura

El complejo posee una infraestructura diseñada para soportar una elevada afluencia de personas y garantizar la operación simultánea de múltiples actividades comerciales y de servicios.

A nivel general, la infraestructura contempla diferentes niveles funcionales destinados a operaciones comerciales, administrativas, técnicas y de soporte.

Distribución General

Nivel	Función Principal
Subsuelo	Estacionamientos, oficinas de parking, áreas técnicas y locales de servicios
Nivel Principal	Locales comerciales, supermercado, plaza de comidas, farmacias y servicios
Entrepiso	Instituciones financieras, servicios médicos, gimnasio y oficinas
Segundo Nivel	Locales comerciales, complejo cinematografico y circulación de clientes
Tercer Nivel	Grandes locales comerciales

El complejo dispone además de diferentes modalidades de estacionamiento, incluyendo espacios subterráneos, estacionamientos exteriores y estructuras elevadas destinadas al ingreso de clientes y visitantes.

Como parte de la infraestructura de soporte operativo, el shopping dispone de áreas administrativas, oficinas técnicas, centros de monitoreo, espacios destinados al mantenimiento de instalaciones y sistemas de respaldo eléctrico para garantizar la continuidad de servicios esenciales ante interrupciones del suministro energético.

2.4 Áreas Organizacionales

La operación del centro comercial requiere la coordinación permanente de diversas áreas funcionales, cada una con responsabilidades específicas dentro de la gestión diaria.

Las principales áreas organizacionales identificadas para el presente estudio son las siguientes:

Área	Función Principal
Administración	Gestión general del centro comercial
Finanzas	Administración financiera y presupuestaria
Comercial	Gestión de locatarios y espacios comerciales
Marketing	Promoción institucional y campañas comerciales
Tecnología	Soporte tecnológico e infraestructura informática
Atención al Cliente	Gestión de consultas, reclamos y asistencia a visitantes
Parking	Administración del sistema de estacionamientos
Seguridad	Protección física y monitoreo del complejo
Mantenimiento	Conservación de infraestructura e instalaciones
Limpieza	Higiene y mantenimiento de espacios comunes

La interacción permanente entre estas áreas resulta indispensable para mantener la continuidad operativa del shopping y garantizar una experiencia adecuada para clientes, visitantes y empresas locatarias.

2.5 Servicios Críticos

Desde una perspectiva de continuidad del negocio, se consideran servicios críticos aquellos cuya indisponibilidad podría afectar significativamente la operación normal del centro comercial.

Se identifican como servicios esenciales:

- Operación del sistema de estacionamiento.
- Atención al cliente.
- Infraestructura eléctrica.
- Generación eléctrica de respaldo.
- Sistemas de videovigilancia (CCTV).
- Control de accesos.
- Redes de comunicaciones.
- Conectividad a Internet.
- Telefonía corporativa.
- Sistemas administrativos.
- Infraestructura tecnológica.
- Servicios de limpieza.
- Servicios de mantenimiento.
- Coordinación de seguridad física.

La disponibilidad de estos servicios constituye un elemento fundamental para garantizar el funcionamiento seguro y continuo del complejo comercial.

2.6 Dependencias Operativas

La continuidad de las operaciones depende de múltiples relaciones entre recursos internos y proveedores externos.

Dependencias Internas

- Administración.
- Tecnología.
- Seguridad.
- Atención al Cliente.
- Operaciones.
- Parking.
- Finanzas.
- Marketing.
- Mantenimiento.

Dependencias Externas

- Empresas de telecomunicaciones.
- Proveedores de energía eléctrica.
- Empresas de seguridad tercerizada.
- Empresas de limpieza.
- Empresas de mantenimiento especializado.
- Locatarios comerciales.
- Instituciones financieras.
- Supermercado.
- Complejo cinematográfico.
- Empresas proveedoras de tecnología.

La dependencia de terceros representa un aspecto relevante dentro del proceso de gestión de riesgos, ya que cualquier interrupción significativa en alguno de estos servicios podría impactar directa o indirectamente sobre la continuidad operativa.

2.7 Infraestructura Tecnológica

Sin realizar una evaluación técnica sobre la infraestructura informática, es posible identificar la existencia de diversos componentes tecnológicos necesarios para soportar las operaciones del centro comercial.

Entre los principales activos tecnológicos considerados dentro del presente assessment se encuentran:

- Redes corporativas.
- Redes inalámbricas.
- Equipamiento de comunicaciones.
- Sistemas administrativos.
- Correos electrónicos corporativos.
- Sistemas de videovigilancia.
- Sistemas de control de accesos.
- Sistemas de gestión del estacionamiento.
- Sistemas de telefonía.
- Equipamiento de respaldo energético (UPS).
- Generadores eléctricos.
- Equipamiento informático utilizado por las distintas áreas administrativas.

La disponibilidad y correcto funcionamiento de estos componentes resulta esencial para garantizar la continuidad de las operaciones y la prestación de servicios a clientes, locatarios y colaboradores.

2.8 Contexto de Riesgo

La operación de un centro comercial moderno implica la exposición permanente a riesgos provenientes de diferentes dominios, los cuales pueden afectar tanto la continuidad del negocio como la seguridad de la información y la experiencia de clientes y visitantes.

Desde una perspectiva de gestión de riesgos, los principales escenarios identificados corresponden a las siguientes categorías:

Categoría	Ejemplos
Tecnológicos	Ransomware, malware, phishing, interrupción de servicios tecnológicos, fuga de información
Humanos	Error humano, fraude interno, ingeniería social, accesos indebidos
Operacionales	Cortes de energía, fallas de comunicaciones, indisponibilidad de sistemas críticos
Físicos	Intrusión, vandalismo, robo, daños a infraestructura
Ambientales	Incendios, inundaciones, tormentas y otros eventos naturales
Terceros	Fallas de proveedores críticos, interrupción de servicios contratados, incumplimientos operativos

La identificación temprana de estos escenarios constituye el punto de partida para la evaluación de riesgos desarrollada en los capítulos siguientes, permitiendo establecer prioridades de tratamiento y recomendaciones orientadas a fortalecer la resiliencia organizacional.

3. Alcance del Assessment

3.1 Objetivo del Assessment

El presente Assessment tiene como finalidad establecer el alcance de la evaluación de riesgos desarrollada en este documento, definiendo los activos, procesos, servicios e infraestructura considerados dentro del análisis, así como las exclusiones necesarias para mantener el carácter independiente, académico y no intrusivo del estudio.

La correcta definición del alcance constituye una práctica fundamental dentro de cualquier proceso de gestión de riesgos, ya que permite delimitar claramente el objeto de evaluación, optimizar la identificación de riesgos y garantizar que las conclusiones obtenidas sean coherentes con los objetivos establecidos.

En este caso, el Assessment se centra exclusivamente en la identificación y evaluación de riesgos asociados a la infraestructura observable, los procesos operativos generales y los servicios críticos que soportan el funcionamiento de un centro comercial moderno, tomando como referencia al Montevideo Shopping como caso de estudio independiente.

El análisis no pretende determinar el estado real de seguridad de la organización ni emitir conclusiones sobre controles específicos implementados, sino construir un escenario de referencia basado en estándares internacionales de gestión de riesgos y resiliencia organizacional.

3.2 Activos Incluidos

El Assessment contempla aquellos activos cuya disponibilidad resulta esencial para garantizar la continuidad operativa del centro comercial y la prestación normal de servicios a clientes, locatarios y colaboradores.

Los activos fueron identificados desde una perspectiva funcional, agrupándolos en diferentes dominios para facilitar su posterior análisis de riesgos.

Activos considerados

Categoría	Alcance
Infraestructura física	Edificio, estacionamientos, oficinas, áreas comunes e instalaciones generales.
Infraestructura tecnológica	Equipamiento informático, redes, sistemas administrativos y servicios tecnológicos.
Servicios críticos	Electricidad, comunicaciones, videovigilancia, parking, atención al cliente y mantenimiento.
Recursos humanos	Personal propio y empresas tercerizadas que participan en la operación.
Información	Información administrativa, financiera y operativa utilizada durante la gestión diaria.
Proveedores críticos	Empresas externas cuya disponibilidad resulta necesaria para garantizar la continuidad del negocio.

La identificación detallada de estos activos será desarrollada en el Capítulo 5 del presente documento.

3.3 Infraestructura Considerada

Con el objetivo de comprender adecuadamente el contexto operativo, el Assessment considera la infraestructura observable que participa directa o indirectamente en el funcionamiento del centro comercial.

Accesos

Se consideran los distintos puntos de ingreso y egreso utilizados por clientes, colaboradores, proveedores y servicios de emergencia.

Estos accesos representan un componente relevante dentro del análisis debido a su relación con la seguridad física, el control de personas y la continuidad de las operaciones.

Entre ellos se incluyen:

- Accesos principales para clientes.
- Accesos secundarios.
- Ingresos para proveedores.
- Accesos de carga y descarga.
- Salidas de emergencia.
- Accesos vehiculares.

Estacionamientos

El sistema de estacionamiento constituye uno de los servicios operativos más importantes del complejo comercial.

Dentro del alcance del Assessment se consideran:

- Estacionamientos subterráneos.
- Estacionamientos exteriores.
- Estacionamientos elevados.
- Barreras automáticas.
- Sistemas de control de ingreso y egreso.
- Oficinas administrativas del parking.
- Equipamiento asociado a la operación.

La disponibilidad del servicio resulta crítica para la experiencia de clientes y para la operación diaria del centro comercial.

Áreas Comunes

Las áreas comunes representan espacios de circulación permanente donde convergen clientes, locatarios y personal operativo.

Dentro del análisis se consideran:

- Pasillos comerciales.
- Plaza de comidas.
- Áreas de descanso.
- Sanitarios.
- Escaleras mecánicas.
- Ascensores.
- Espacios de circulación.
- Señalización general.

Estas áreas poseen una elevada dependencia de infraestructura eléctrica, sistemas de seguridad física y procesos de mantenimiento.

Administración

El Assessment contempla las funciones administrativas necesarias para la gestión operativa del centro comercial.

Entre ellas:

- Administración General.
- Finanzas.
- Comercial.
- Marketing.
- Atención al Cliente.
- Gestión administrativa.
- Coordinación operativa.

Estas áreas administran procesos críticos relacionados con la continuidad del negocio y la operación diaria.

Parking

Se considera la infraestructura y los procesos asociados a la gestión del estacionamiento.

Incluye:

- Operación del servicio.
- Oficinas administrativas.
- Equipamiento operativo.
- Procesos de atención al usuario.
- Coordinación con seguridad.
- Procesos de mantenimiento.

La indisponibilidad de este servicio podría generar impactos operativos, financieros y reputacionales.

Tecnología

Desde una perspectiva de gestión de riesgos, el Assessment contempla la existencia de infraestructura tecnológica que soporta las operaciones del shopping.

Entre los componentes considerados se encuentran:

- Redes de comunicación.
- Equipamiento de red.
- Sistemas administrativos.
- Correo electrónico.
- Equipamiento informático.
- Infraestructura de comunicaciones.
- Sistemas de videovigilancia.
- Control de accesos.
- Sistemas de gestión del estacionamiento.
- Infraestructura eléctrica de respaldo.

No se realiza evaluación técnica sobre ninguno de estos componentes.

Seguridad

La seguridad física constituye un elemento esencial para preservar la continuidad de las operaciones.

Dentro del alcance se consideran:

- Personal de seguridad.
- Empresas tercerizadas.
- Centro de monitoreo.
- Sistemas CCTV.
- Control de accesos.
- Patrullaje interno.
- Coordinación con servicios de emergencia.

El análisis se realiza desde una perspectiva de gestión de riesgos, sin evaluar procedimientos internos específicos.

3.4 Exclusiones

Con el objetivo de preservar el carácter independiente y no intrusivo del presente caso de estudio, determinadas actividades quedaron expresamente excluidas del alcance del Assessment.

Estas exclusiones garantizan que el documento mantenga un enfoque estratégico de gestión de riesgos y no sea interpretado como una auditoría técnica o una evaluación oficial de la organización.

Actividades excluidas

Exclusión	Justificación
Servidores internos	No se realizó acceso ni evaluación sobre infraestructura tecnológica interna.
Configuraciones de seguridad	No se revisaron configuraciones de dispositivos, sistemas o aplicaciones.
Bases de datos	No se analizó información almacenada por la organización.
Auditorías técnicas	El documento no constituye una auditoría de infraestructura informática.
Pruebas de penetración (Pentesting)	No se ejecutaron actividades ofensivas ni pruebas de explotación.
Escaneos de vulnerabilidades	No se realizaron análisis técnicos sobre activos internos.
Información confidencial	No se tuvo acceso a documentación, procesos o información restringida.

Entrevistas al personal	No se efectuaron entrevistas ni relevamientos internos.
Evaluaciones de cumplimiento	No se realizó una auditoría de cumplimiento respecto de normas o regulaciones.

3.5 Consideraciones del Assessment

Los resultados presentados en este documento deben interpretarse como una evaluación preliminar basada en principios de gestión de riesgos y buenas prácticas internacionales.

En consecuencia:

- Las amenazas, vulnerabilidades y riesgos identificados representan escenarios potenciales propios de organizaciones del sector retail y no deben interpretarse como hallazgos confirmados dentro del Montevideo Shopping.
- La criticidad asignada responde a un ejercicio metodológico, no a hallazgos confirmados. .
- Las recomendaciones formuladas tienen carácter preventivo y estratégico, orientadas a fortalecer la resiliencia organizacional y servir como referencia para futuras iniciativas de gestión de riesgos.

El presente Assessment no sustituye una auditoría formal, un proceso de certificación ni una evaluación técnica autorizada por la organización, constituyendo exclusivamente un caso de estudio independiente desarrollado conforme a estándares internacionales de Gobernanza, Gestión de Riesgos y Cumplimiento (GRC).

4. Metodología

4.1 Introducción

La metodología aplicada durante el presente Assessment fue desarrollada siguiendo un enfoque estructurado de gestión de riesgos, alineado con estándares y marcos internacionales ampliamente reconocidos en materia de Gobernanza, Gestión de Riesgos y Cumplimiento (Governance, Risk & Compliance – GRC).

El propósito de la metodología consiste en proporcionar un proceso sistemático para identificar activos críticos, analizar amenazas y vulnerabilidades, evaluar el nivel de exposición al riesgo y definir recomendaciones orientadas a fortalecer la resiliencia organizacional.

El enfoque metodológico permite desarrollar una evaluación consistente, repetible y alineada con los principios utilizados por organizaciones especializadas en gestión de riesgos y ciberseguridad.

Nota metodológica: La metodología fue aplicada sobre un escenario de referencia construido con base en información pública, conocimiento general del funcionamiento de un centro comercial y buenas prácticas internacionales.

4.2 Marcos de Referencia

Para el desarrollo del Assessment se tomaron como referencia los siguientes estándares internacionales.

Marco de Referencia	Aplicación dentro del Assessment
ISO/IEC 27001:2022	Identificación de activos, gestión de riesgos y controles de seguridad de la información.
ISO 31000:2018	Gestión integral de riesgos y proceso de evaluación del riesgo.
NIST Cybersecurity Framework (CSF) 2.0	Identificación, protección, detección, respuesta y recuperación frente a incidentes.
CIS Controls v8	Controles priorizados para fortalecer la postura de ciberseguridad.

La combinación de estos marcos metodológicos proporciona una visión integral de la gestión de riesgos, permitiendo abordar tanto aspectos organizacionales como tecnológicos.

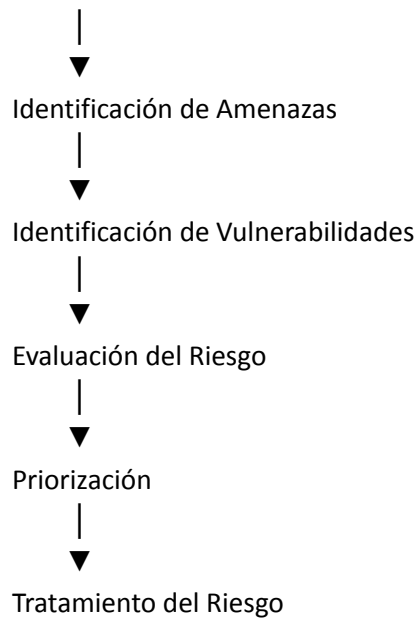
4.3 Proceso Metodológico

El Assessment fue desarrollado mediante un proceso secuencial compuesto por siete etapas principales.

Comprensión del Contexto



Identificación de Activos



Cada una de estas etapas se describe a continuación.

4.4 Identificación de Activos

La primera etapa consistió en identificar los activos que soportan las operaciones del centro comercial.

Se consideraron cinco grandes categorías de activos:

- Infraestructura física.
- Infraestructura tecnológica.
- Información.
- Recursos humanos.
- Servicios y proveedores críticos.

Cada activo fue posteriormente clasificado considerando su importancia para la continuidad del negocio y su nivel de criticidad desde la perspectiva de la confidencialidad, integridad y disponibilidad (Modelo CIA).

Esta clasificación constituye la base para el análisis de amenazas y vulnerabilidades desarrollado en los capítulos posteriores.

4.5 Identificación de Amenazas

Una vez identificados los activos, se procedió al análisis de las amenazas que podrían afectar su disponibilidad, integridad o confidencialidad.

Las amenazas fueron clasificadas según su origen.

Categoría	Ejemplos
Tecnológicas	Malware, ransomware, explotación de vulnerabilidades, ataques DDoS.
Humanas	Phishing, ingeniería social, fraude interno, error humano.
Operacionales	Fallas de energía, indisponibilidad de servicios, interrupción de proveedores.
Físicas	Robo, vandalismo, intrusión, sabotaje.
Ambientales	Incendios, inundaciones, tormentas, eventos climáticos.

La identificación de amenazas permitió construir distintos escenarios de riesgo aplicables al entorno de un centro comercial moderno.

4.6 Identificación de Vulnerabilidades

Posteriormente se analizaron las posibles vulnerabilidades que podrían facilitar la materialización de las amenazas previamente identificadas.

Debido al carácter no intrusivo del Assessment, las vulnerabilidades fueron definidas como escenarios potenciales basados en buenas prácticas internacionales y riesgos comúnmente observados en organizaciones del sector retail.

Entre las vulnerabilidades consideradas se incluyen:

- Dependencia de proveedores críticos.
- Procesos manuales.
- Controles de acceso insuficientes.
- Concientización limitada del personal.
- Dependencia tecnológica.
- Puntos únicos de falla.
- Falta de redundancia operativa.
- Gestión insuficiente de activos.

Estas vulnerabilidades serán desarrolladas con mayor detalle en el Capítulo 7.

4.7 Evaluación del Riesgo

La evaluación del riesgo fue realizada considerando dos variables fundamentales:

- Probabilidad de ocurrencia.

- Impacto potencial sobre la organización.

Cada escenario fue analizado considerando su posible impacto sobre:

- Continuidad operativa.
- Disponibilidad de servicios.
- Seguridad de la información.
- Impacto financiero.
- Impacto reputacional.
- Cumplimiento de procesos.
- Experiencia de clientes y locatarios.

El resultado de esta evaluación permitió determinar el nivel de criticidad de cada riesgo identificado.

4.8 Escala de Probabilidad

La probabilidad representa la posibilidad de que un escenario de riesgo llegue a materializarse.

Se utilizó la siguiente escala de valoración.

Valor	Nivel	Descripción
1	Muy Baja	Escenario altamente improbable.
2	Baja	Poco probable.
3	Media	Probabilidad moderada.
4	Alta	Alta posibilidad de ocurrencia.
5	Muy Alta	Escenario esperado o frecuente.

4.9 Escala de Impacto

El impacto representa las consecuencias que tendría un incidente sobre la organización.

Valor	Nivel	Descripción
-------	-------	-------------

1	Insignificante	Impacto mínimo sobre la operación.
2	Menor	Afectación limitada y fácilmente recuperable.
3	Moderado	Interrupción parcial de servicios.
4	Alto	Impacto significativo sobre procesos críticos.
5	Crítico	Interrupción severa de la continuidad del negocio.

4.10 Matriz de Evaluación del Riesgo

El nivel de riesgo fue determinado mediante la combinación entre la probabilidad de ocurrencia y el impacto estimado para cada escenario analizado.

La siguiente matriz servirá como referencia para la clasificación presentada en el Capítulo 9.

Impacto / Probabilidad	1	2	3	4	5
5	Medio	Alto	Alto	Crítico	Crítico
4	Medio	Medio	Alto	Alto	Crítico
3	Bajo	Medio	Medio	Alto	Alto
2	Bajo	Bajo	Medio	Medio	Alto
1	Bajo	Bajo	Bajo	Medio	Medio

4.11 Tratamiento del Riesgo

Una vez evaluados y priorizados los riesgos, se definieron estrategias de tratamiento orientadas a reducir la exposición de la organización.

Las alternativas consideradas corresponden a las establecidas por la norma ISO 31000:

Estrategia	Descripción
Evitar	Eliminar la actividad que origina el riesgo.
Mitigar	Implementar controles para reducir la probabilidad o el impacto.
Transferir	Compartir el riesgo mediante seguros o contratos con terceros.
Aceptar	Asumir el riesgo cuando su nivel resulte aceptable para la organización.

Las recomendaciones desarrolladas en los capítulos posteriores fueron formuladas considerando estas estrategias de tratamiento.

4.12 Conclusiones de la Metodología

La metodología aplicada proporciona un marco estructurado para la identificación, evaluación y priorización de riesgos, permitiendo desarrollar un análisis consistente y alineado con las mejores prácticas internacionales en materia de gestión de riesgos y ciberseguridad.

El uso combinado de ISO/IEC 27001, ISO 31000, NIST Cybersecurity Framework 2.0 y CIS Controls v8 permite integrar una visión estratégica y operativa del riesgo, considerando tanto los procesos organizacionales como la infraestructura tecnológica que soporta la operación del centro comercial.

En los capítulos siguientes, esta metodología servirá como base para la construcción del inventario de activos, la identificación de amenazas y vulnerabilidades, la evaluación de riesgos y la definición del plan de tratamiento correspondiente.

5. Inventario y Clasificación de Activos

5.1 Objetivo

La identificación y clasificación de activos constituye una de las etapas más relevantes dentro del proceso de gestión de riesgos, ya que permite determinar cuáles son los recursos esenciales para el funcionamiento de la organización y establecer el nivel de protección que requieren.

En el contexto de un centro comercial, los activos no se limitan únicamente a la infraestructura física o tecnológica. También incluyen información, procesos, servicios, personas y proveedores cuya disponibilidad resulta indispensable para garantizar la continuidad del negocio y la prestación normal de los servicios.

El objetivo del presente capítulo es desarrollar un inventario estructurado de los activos más relevantes asociados a la operación del Montevideo Shopping, estableciendo su clasificación, criticidad y dependencia operativa como base para la evaluación de riesgos desarrollada en los capítulos posteriores.

Nota metodológica: El presente inventario corresponde a un escenario de referencia elaborado con fines académicos y metodológicos.

5.2 Metodología de Clasificación

El inventario de activos fue desarrollado siguiendo un enfoque basado en riesgos, considerando aquellos recursos cuya indisponibilidad podría generar impactos significativos sobre la continuidad operativa, la prestación de servicios, la seguridad de la información o la reputación de la organización.

Los activos fueron agrupados en seis categorías principales:

Categoría	Descripción
Activos Físicos	Infraestructura, instalaciones y equipamiento físico que soporta la operación del centro comercial.
Activos Tecnológicos	Hardware, software, redes, aplicaciones y sistemas utilizados para la operación diaria.
Activos de Información	Información física o digital utilizada para la gestión administrativa y operativa.
Activos Humanos	Personal propio, contratistas y empresas tercerizadas que participan en la operación.

Servicios Críticos	Servicios cuya indisponibilidad afectaría significativamente la continuidad del negocio.
Proveedores Críticos	Organizaciones externas que brindan servicios esenciales para el funcionamiento del centro comercial.

Cada activo fue posteriormente evaluado considerando tres dimensiones fundamentales de seguridad de la información:

- Confidencialidad.
- Integridad.
- Disponibilidad.

Adicionalmente, se asignó un nivel de criticidad basado en el impacto potencial que tendría la indisponibilidad del activo sobre la operación del negocio.

5.3 Modelo CIA

La clasificación de activos fue realizada utilizando el modelo **CIA (Confidentiality, Integrity & Availability)**, ampliamente utilizado en sistemas de gestión de seguridad de la información y metodologías internacionales de gestión de riesgos.

Este modelo permite evaluar la importancia relativa de cada activo desde tres perspectivas complementarias.

Confidencialidad

La confidencialidad representa el nivel de protección requerido para evitar el acceso no autorizado a la información o a los recursos de la organización.

Un nivel elevado de confidencialidad implica que la divulgación del activo podría generar consecuencias legales, financieras, reputacionales u operativas.

Ejemplos

- Información financiera.
- Información de colaboradores.
- Contratos.
- Credenciales.
- Documentación administrativa.

Integridad

La integridad representa la necesidad de garantizar que la información o el activo permanezcan completos, precisos y libres de modificaciones no autorizadas.

La pérdida de integridad puede provocar errores operativos, decisiones incorrectas o interrupciones en la prestación de servicios.

Ejemplos

- Sistemas administrativos.
- Información financiera.
- Sistema de estacionamiento.
- Base de datos de proveedores.

Disponibilidad

La disponibilidad representa la capacidad del activo para encontrarse operativo cuando sea requerido por la organización.

En un entorno comercial, la indisponibilidad de determinados activos puede generar interrupciones inmediatas sobre la operación diaria.

Ejemplos

- Energía eléctrica.
- CCTV.
- Parking.
- Redes.
- Sistemas administrativos.

5.4 Escala de Clasificación CIA

Cada activo fue clasificado utilizando la siguiente escala.

Valor	Descripción
Alta (A)	La pérdida afectaría gravemente la continuidad del negocio.
Media (M)	La pérdida produciría un impacto moderado sobre la operación.
Baja (B)	El impacto sería limitado y fácilmente recuperable.

5.5 Criterios de Criticidad

Con el objetivo de priorizar los activos identificados, se definieron cuatro niveles de criticidad.

Nivel	Descripción
Crítica	La indisponibilidad del activo interrumpe significativamente la operación del centro comercial.
Alta	El activo resulta indispensable para múltiples procesos críticos.
Media	Su indisponibilidad afecta parcialmente la operación.
Baja	Su indisponibilidad genera impactos limitados o fácilmente recuperables.

La criticidad fue determinada considerando los siguientes factores:

- Impacto sobre la continuidad operativa.
- Impacto económico.
- Impacto reputacional.
- Dependencia de otros procesos.
- Nivel de exposición al riesgo.
- Necesidad de recuperación inmediata.

5.6 Clasificación General de Activos

El siguiente esquema resume la estructura utilizada para el inventario desarrollado en este Assessment.

Categoría	Código
-----------	--------

Activos Físicos	AF
Activos Tecnológicos	AT
Activos de Información	AI
Activos Humanos	AH
Servicios Críticos	SC
Proveedores Críticos	PC

Esta codificación será utilizada a lo largo del documento para facilitar la identificación y trazabilidad de cada activo durante la evaluación de riesgos.

5.7 Relación entre Activos y Gestión de Riesgos

El inventario de activos constituye el punto de partida para la construcción del modelo de gestión de riesgos presentado en este Assessment.

Cada activo identificado será posteriormente relacionado con:

- Amenazas potenciales.
- Vulnerabilidades asociadas.
- Riesgos identificados.
- Controles existentes (supuestos).
- Controles recomendados.
- Nivel de criticidad.
- Estrategias de tratamiento del riesgo.

Esta relación permitirá desarrollar una evaluación integral orientada a priorizar aquellos escenarios con mayor impacto potencial sobre la continuidad del negocio.

Este inventario de activos físicos es la base para identificar amenazas y vulnerabilidades en los capítulos siguientes.

5.8 Inventario de Activos Físicos

Introducción

Los activos físicos representan la infraestructura tangible sobre la cual se desarrollan las operaciones del centro comercial. Su disponibilidad y correcto funcionamiento resultan esenciales para garantizar la continuidad de los servicios, la seguridad de clientes y colaboradores, así como la operación diaria de los distintos procesos de negocio.

Dentro del presente Assessment, los activos físicos fueron identificados considerando su importancia para la continuidad operativa, el impacto potencial asociado a su indisponibilidad y su relación con otros procesos críticos de la organización.

Nota metodológica: La clasificación presentada responde a un escenario de referencia construido para el presente Assessment.

5.9 Registro de Activos Físicos

ID	Activo	Descripción	Responsable (Referencia)	C	I	D	Criticidad
AF-001	Edificio Principal	Infraestructura que alberga todas las operaciones comerciales.	Administración	M	A	A	Crítica
AF-002	Estacionamiento Subterráneo	Área destinada al estacionamiento de vehículos.	Parking	B	A	A	Alta
AF-003	Estacionamiento Exterior	Espacios de estacionamiento exteriores.	Parking	B	M	A	Alta
AF-004	Estacionamiento Elevado	Infraestructura elevada destinada al estacionamiento.	Parking	B	M	A	Alta
AF-005	Oficinas Administrativas	Espacios utilizados para la gestión administrativa.	Administración	A	A	A	Alta
AF-006	Oficinas de Parking	Gestión operativa del estacionamiento.	Parking	M	A	A	Alta

AF-007	Centro de Atención al Cliente	Atención a clientes y visitantes.	Atención al Cliente	M	A	A	Alta
AF-008	Plaza de Comidas	Área gastronómica de alta concurrencia.	Operaciones	B	M	A	Alta
AF-009	Áreas Comunes	Pasillos y espacios públicos.	Operaciones	B	M	A	Alta
AF-010	Locales Comerciales	Espacios destinados a empresas locatarias.	Comercial	M	A	A	Crítica
AF-011	Complejo Cinematográfico	Infraestructura destinada al entretenimiento.	Operaciones	B	M	A	Media
AF-012	Escaleras Mecánicas	Sistema de circulación vertical.	Mantenimiento	B	A	A	Alta
AF-013	Ascensores	Transporte vertical de personas.	Mantenimiento	B	A	A	Alta
AF-014	Salidas de Emergencia	Infraestructura para evacuación.	Seguridad	B	A	A	Crítica
AF-015	Puertas de Acceso Principal	Control de ingreso de clientes.	Seguridad	B	A	A	Alta
AF-016	Accesos para Proveedores	Ingreso de mercadería y servicios.	Operaciones	B	A	A	Alta
AF-017	Áreas Técnicas	Espacios destinados a infraestructura técnica.	Tecnología	M	A	A	Alta
AF-018	Sala Eléctrica	Distribución eléctrica principal.	Mantenimiento	B	A	A	Crítica
AF-019	Generadores Eléctricos	Respaldo energético ante cortes.	Mantenimiento	B	A	A	Crítica
AF-020	UPS	Sistemas de alimentación ininterrumpida.	Tecnología	B	A	A	Alta
AF-021	Centro de Monitoreo CCTV	Supervisión de seguridad física.	Seguridad	M	A	A	Crítica
AF-022	Depósitos	Almacenamiento de materiales.	Operaciones	M	A	M	Media

AF-023	Sanitarios Públicos	Servicios sanitarios.	Mantenimiento	B	M	A	Media
AF-024	Cuartos de Comunicaciones	Infraestructura para equipos tecnológicos.	Tecnología	A	A	A	Crítica
AF-025	Áreas de Mantenimiento	Soporte para reparaciones e infraestructura.	Mantenimiento	B	A	A	Alta

5.10 Clasificación por Nivel de Criticidad

Con el objetivo de priorizar la protección de los activos identificados, cada elemento fue clasificado de acuerdo con su nivel de criticidad para la continuidad del negocio.

Activos Críticos

Los siguientes activos presentan un impacto extremadamente elevado sobre la continuidad operativa.

Activo	Justificación
Edificio Principal	Infraestructura indispensable para todas las operaciones.
Locales Comerciales	Fuente principal de ingresos y actividad comercial.
Sala Eléctrica	Distribución de energía hacia todo el complejo.
Generadores Eléctricos	Garantizan continuidad ante fallas del suministro.
Centro de Monitoreo CCTV	Soporta la seguridad física del complejo.
Cuartos de Comunicaciones	Alojan infraestructura tecnológica crítica.
Salidas de Emergencia	Elemento esencial para la seguridad de las personas.

Activos de Alta Criticidad

Corresponden a activos cuya indisponibilidad afectaría significativamente la operación diaria.

- Estacionamientos.
- Oficinas Administrativas.
- Oficinas de Parking.
- Escaleras Mecánicas.
- Ascensores.
- Plaza de Comidas.
- Áreas Comunes.
- Centro de Atención al Cliente.
- UPS.
- Áreas Técnicas.
- Puertas de Acceso.
- Accesos para Proveedores.
- Áreas de Mantenimiento.

Activos de Criticidad Media

Son activos cuya indisponibilidad genera impactos limitados o temporales.

- Complejo Cinematográfico.
- Depósitos.
- Servicios Sanitarios Públicos.

5.11 Análisis del Inventario Físico

El análisis realizado permite identificar una elevada dependencia de la organización respecto a determinados activos físicos cuya indisponibilidad podría comprometer significativamente la continuidad operativa.

Entre ellos destacan la infraestructura edilicia, los sistemas de respaldo energético, las áreas destinadas a comunicaciones y los sistemas asociados a la seguridad física.

Asimismo, se observa una fuerte interdependencia entre los activos físicos y los componentes tecnológicos que soportan los procesos administrativos y comerciales. La indisponibilidad de instalaciones como la sala eléctrica, los cuartos de comunicaciones o el centro de monitoreo tendría un efecto cascada sobre múltiples servicios esenciales.

Desde una perspectiva de gestión de riesgos, los activos clasificados como críticos deberán recibir mayor atención durante la evaluación de amenazas y vulnerabilidades desarrollada en los capítulos

siguientes, priorizando la implementación de controles orientados a preservar su disponibilidad, integridad y resiliencia.

5.12 Recomendaciones Generales

Como resultado del inventario desarrollado, se identifican las siguientes oportunidades de mejora:

- Mantener un inventario actualizado de todos los activos físicos.
- Definir responsables formales para cada activo crítico.
- Documentar procedimientos de mantenimiento preventivo y correctivo.
- Implementar revisiones periódicas sobre infraestructura crítica.
- Verificar la capacidad operativa de los sistemas de respaldo eléctrico.
- Evaluar periódicamente las condiciones de las rutas de evacuación y salidas de emergencia.
- Incorporar indicadores de disponibilidad para los activos clasificados como críticos.
- Integrar el inventario físico con el proceso de gestión de activos del Sistema de Gestión de Seguridad d

5.13 Inventario de Activos Tecnológicos

Introducción

La infraestructura tecnológica constituye uno de los pilares fundamentales para el funcionamiento de un centro comercial moderno. La operación diaria depende de la disponibilidad permanente de múltiples sistemas de información, redes de comunicación, equipamiento informático y servicios digitales que soportan tanto los procesos administrativos como la prestación de servicios a clientes, locatarios y proveedores.

Desde una perspectiva de gestión de riesgos, la interrupción o compromiso de estos activos puede generar impactos significativos sobre la continuidad operativa, la seguridad de la información, la experiencia de los usuarios y la reputación institucional.

El presente inventario identifica los principales activos tecnológicos que, de manera razonable y conforme a las prácticas habituales del sector retail, pueden formar parte del entorno tecnológico de un centro comercial como el Montevideo Shopping.

Nota metodológica: Los activos incluidos en este capítulo corresponden a un escenario de referencia elaborado con base en información pública y supuestos razonables. Su inclusión tiene fines exclusivamente académicos y metodológicos.

5.14 Registro de Activos Tecnológicos

ID	Activo	Descripción	Responsable (Referencia)	C	I	D	Críticidad
AT-001	Red Corporativa	Infraestructura de comunicación interna.	Tecnología	A	A	A	Crítica
AT-002	Red Wi-Fi Corporativa	Conectividad para personal autorizado.	Tecnología	A	A	A	Alta
AT-003	Red Wi-Fi para Visitantes	Servicio de acceso inalámbrico para clientes.	Tecnología	M	M	A	Media
AT-004	Firewall Perimetral	Protección del perímetro de red.	Tecnología	A	A	A	Crítica

AT-005	Switches de Red	Distribución de conectividad.	Tecnología	M	A	A	Alta
AT-006	Routers	Interconexión de redes.	Tecnología	M	A	A	Alta
AT-007	Access Points	Cobertura inalámbrica.	Tecnología	B	M	A	Media
AT-008	Sistema de Correo Electrónico	Comunicación corporativa.	Tecnología	A	A	A	Alta
AT-009	Dominio Corporativo	Gestión de identidades y autenticación.	Tecnología	A	A	A	Crítica
AT-010	Active Directory <i>(supuesto de referencia)</i>	Administración centralizada de usuarios.	Tecnología	A	A	A	Crítica
AT-011	Equipos de Escritorio	Estaciones de trabajo administrativas.	Tecnología	M	A	A	Alta
AT-012	Computadoras Portátiles	Equipos móviles corporativos.	Tecnología	A	A	A	Alta
AT-013	Impresoras Multifunción	Procesamiento documental.	Tecnología	M	M	M	Baja
AT-014	Sistema CCTV	Videovigilancia del complejo.	Seguridad	M	A	A	Crítica
AT-015	Servidores de Video <i>(categoría de referencia)</i>	Gestión de grabaciones CCTV.	Tecnología	A	A	A	Alta
AT-016	Sistema de Control de Accesos	Gestión de accesos físicos.	Seguridad	A	A	A	Crítica
AT-017	Sistema de Parking	Administración del estacionamiento.	Parking	M	A	A	Alta
AT-018	Sistema de Ticketing Parking	Gestión de tickets y cobros.	Parking	M	A	A	Alta
AT-019	Sistema POS <i>(categoría de referencia)</i>	Terminales de venta de servicios propios.	Operaciones	A	A	A	Alta

AT-020	Sistema Administrativo	Gestión administrativa.	Administración	A	A	A	Crítica
AT-021	Sistema Financiero	Procesos financieros.	Finanzas	A	A	A	Crítica
AT-022	Sistema de Recursos Humanos	Gestión del personal.	RRHH	A	A	A	Alta
AT-023	Plataforma de Atención al Cliente	Gestión de consultas y reclamos.	Atención al Cliente	M	A	A	Alta
AT-024	Sistema de Gestión Documental	Almacenamiento documental.	Administración	A	A	A	Alta
AT-025	Plataforma de Marketing Digital	Gestión institucional.	Marketing	M	A	M	Media
AT-026	DNS Corporativo (categoría de referencia)	Resolución de nombres.	Tecnología	A	A	A	Alta
AT-027	Servidores de Aplicaciones (categoría de referencia)	Ejecución de aplicaciones críticas.	Tecnología	A	A	A	Crítica
AT-028	Servidores de Bases de Datos (categoría de referencia)	Almacenamiento estructurado de información.	Tecnología	A	A	A	Crítica
AT-029	Sistema de Backup (categoría de referencia)	Respaldo de información.	Tecnología	A	A	A	Crítica
AT-030	UPS	Alimentación eléctrica ininterrumpida.	Tecnología	B	A	A	Alta
AT-031	Generadores de Energía	Respaldo energético.	Mantenimiento	B	A	A	Crítica
AT-032	Consola de Monitoreo	Supervisión de infraestructura tecnológica.	Tecnología	M	A	A	Alta

AT-033	Herramientas de Administración Remota	Soporte técnico.	Tecnología	A	A	A	Alta
AT-034	Plataforma de Antivirus / EDR (<i>categoría de referencia</i>)	Protección de endpoints.	Tecnología	A	A	A	Alta
AT-035	Plataforma SIEM (<i>escenario de referencia</i>)	Correlación y monitoreo de eventos de seguridad.	Tecnología	A	A	A	Alta

Nota metodológica: Los activos marcados como "**categoría de referencia**" o "**escenario de referencia**" representan componentes tecnológicos habitualmente presentes en organizaciones de características similares. Su inclusión responde exclusivamente a fines metodológicos y no implica confirmar su existencia en el Montevideo Shopping.

5.15 Clasificación por Criticidad

Activos Críticos

Los siguientes activos fueron clasificados como **Críticos**, debido a que su indisponibilidad podría comprometer significativamente la continuidad operativa.

Activo	Justificación
Red Corporativa	Soporta la comunicación entre sistemas críticos.
Firewall Perimetral	Principal mecanismo de protección del perímetro tecnológico.
Dominio Corporativo	Administración de identidades y autenticación.

Sistema Administrativo	Soporte de procesos operativos esenciales.
Sistema Financiero	Gestión económica y financiera.
Sistema CCTV	Seguridad física y monitoreo continuo.
Sistema de Control de Accesos	Protección de áreas restringidas.
Servidores de Aplicaciones (<i>referencia</i>)	Procesamiento de aplicaciones críticas.
Servidores de Bases de Datos (<i>referencia</i>)	Almacenamiento de información esencial.
Sistema de Backup (<i>referencia</i>)	Recuperación ante incidentes.
Generadores Eléctricos	Continuidad de la infraestructura tecnológica.

Activos de Alta Criticidad

Se clasifican como activos de alta criticidad aquellos cuya indisponibilidad afectaría múltiples procesos organizacionales.

- Red Wi-Fi Corporativa.
- Switches.
- Routers.
- Correo Electrónico.
- Equipos de Escritorio.
- Computadoras Portátiles.
- Sistema de Parking.
- Sistema de Ticketing.
- Sistema de Recursos Humanos.
- Plataforma de Atención al Cliente.
- Sistema de Gestión Documental.
- DNS Corporativo.
- Consola de Monitoreo.
- Herramientas de Administración Remota.
- Plataforma Antivirus / EDR.
- Plataforma SIEM.

Activos de Criticidad Media

- Red Wi-Fi para Visitantes.
- Access Points.
- Plataforma de Marketing Digital.

Activos de Baja Criticidad

- Impresoras Multifunción.

5.16 Análisis del Inventario Tecnológico

El análisis del inventario tecnológico evidencia una elevada dependencia de la organización respecto a los sistemas de información y a la infraestructura de comunicaciones que soportan la operación diaria del centro comercial.

La disponibilidad de la red corporativa, los mecanismos de autenticación, los sistemas administrativos y los servicios de respaldo constituye un factor determinante para garantizar la continuidad del negocio y minimizar el impacto ante incidentes tecnológicos.

Asimismo, se observa una fuerte interdependencia entre los activos tecnológicos y la infraestructura física, particularmente en los sistemas de videovigilancia, control de accesos, estacionamiento y respaldo energético. Esta relación incrementa la necesidad de adoptar un enfoque integral de gestión de riesgos que contemple tanto la seguridad de la información como la continuidad operativa.

Desde la perspectiva de GRC, los activos clasificados como críticos deberán ser considerados prioritarios durante la evaluación de amenazas, vulnerabilidades y planes de tratamiento del riesgo.

5.17 Recomendaciones Generales

Como resultado del inventario tecnológico desarrollado, se identifican las siguientes oportunidades de mejora:

- Mantener un inventario actualizado y formalmente documentado de todos los activos tecnológicos.
- Clasificar los activos según su nivel de criticidad y valor para el negocio.
- Asignar responsables (Asset Owners) para cada activo crítico.
- Implementar procesos de gestión del ciclo de vida de los activos.
- Revisar periódicamente la obsolescencia tecnológica y los planes de renovación.
- Integrar el inventario con los procesos de gestión de cambios, gestión de vulnerabilidades y respuesta a incidentes.

- Verificar la existencia de mecanismos de respaldo, recuperación y redundancia para los activos clasificados como críticos.
- Establecer indicadores de disponibilidad y desempeño que permitan monitorear la salud de la infraestructura tecnológica.

5.18 Inventario de Activos de Información

Introducción

La información constituye uno de los activos más valiosos para cualquier organización, independientemente de su tamaño o sector de actividad. En un entorno comercial, la información soporta procesos administrativos, financieros, comerciales y operativos, permitiendo la toma de decisiones, la prestación de servicios y el cumplimiento de obligaciones legales y contractuales.

Desde la perspectiva de la gestión de riesgos, la pérdida de confidencialidad, integridad o disponibilidad de la información puede generar impactos significativos sobre la continuidad del negocio, la reputación institucional y la confianza de clientes, locatarios y proveedores.

El presente inventario identifica las principales categorías de información que, de forma razonable, pueden existir dentro de un centro comercial como parte de su operación habitual.

Registro de Activos de Información

ID	Activo	Responsable (Referencia)	C	I	D	Criticidad
AI-00 1	Información Financiera	Finanzas	A	A	M	Crítica
AI-00 2	Información Contable	Finanzas	A	A	M	Alta
AI-00 3	Información de Colaboradores	RRHH	A	A	M	Alta

AI-004	Información de Proveedores	Administración	A	A	M	Alta
AI-005	Contratos Comerciales	Comercial	A	A	M	Alta
AI-006	Información de Locatarios	Comercial	A	A	A	Crítica
AI-007	Procedimientos Operativos	Operaciones	M	A	A	Alta
AI-008	Manuales Técnicos	Tecnología	M	A	M	Media
AI-009	Inventario de Activos	Tecnología	M	A	A	Alta
AI-010	Planes de Emergencia	Seguridad	M	A	A	Crítica
AI-011	Información Administrativa	Administración	A	A	M	Alta
AI-012	Registros de Incidentes	Seguridad	A	A	M	Alta
AI-013	Información de Mantenimiento	Mantenimiento	M	A	M	Media
AI-014	Documentación de Seguridad	Seguridad	A	A	A	Crítica
AI-015	Copias de Respaldo (<i>Categoría de referencia</i>)	Tecnología	A	A	A	Crítica

5.19 Inventario de Activos Humanos

Introducción

Los recursos humanos representan un componente fundamental dentro del proceso de gestión de riesgos. Las personas participan activamente en la operación, administración, supervisión y mantenimiento de los procesos críticos, siendo además uno de los principales objetivos de amenazas como el phishing, la ingeniería social o el fraude.

El presente inventario identifica los principales grupos de colaboradores y terceros que participan en el funcionamiento del centro comercial.

Registro de Activos Humanos

ID	Activo	Función Principal	Criticidad
AH-001	Dirección	Dirección estratégica	Crítica
AH-002	Gerencia General	Coordinación operativa	Crítica
AH-003	Administración	Gestión administrativa	Alta
AH-004	Finanzas	Gestión financiera	Alta
AH-005	Tecnología	Infraestructura tecnológica	Crítica
AH-006	Seguridad Física	Protección del complejo	Crítica
AH-007	Seguridad Tercerizada	Vigilancia y monitoreo	Alta
AH-008	Atención al Cliente	Atención a visitantes	Alta
AH-009	Parking	Gestión del estacionamiento	Alta
AH-010	Marketing	Comunicación institucional	Media
AH-011	Comercial	Gestión de locatarios	Alta
AH-012	Mantenimiento	Conservación de infraestructura	Crítica
AH-013	Limpieza	Higiene del complejo	Media
AH-014	Empresas Contratistas	Servicios especializados	Alta
AH-015	Locatarios	Operación comercial	Crítica

5.20 Inventario de Servicios Críticos

Introducción

Los servicios críticos son aquellos cuya interrupción puede afectar de forma inmediata la continuidad operativa del centro comercial.

Estos servicios requieren mecanismos adecuados de monitoreo, respaldo y recuperación.

Registro de Servicios Críticos

ID	Servicio	Criticidad
SC-001	Energía Eléctrica	Crítica
SC-002	Generación Eléctrica de Respaldo	Crítica
SC-003	Conectividad a Internet	Crítica
SC-004	Redes Corporativas	Crítica
SC-005	Videovigilancia (CCTV)	Crítica
SC-006	Control de Accesos	Crítica
SC-007	Sistema de Parking	Alta
SC-008	Atención al Cliente	Alta
SC-009	Telefonía	Alta
SC-010	Correo Electrónico	Alta
SC-011	Mantenimiento	Alta
SC-012	Limpieza	Media
SC-013	Escaleras Mecánicas	Alta
SC-014	Ascensores	Alta
SC-015	Gestión Administrativa	Crítica

5.21 Inventario de Proveedores Críticos

Introducción

La continuidad operativa del centro comercial depende en gran medida de la disponibilidad de servicios prestados por terceros.

La gestión adecuada de proveedores constituye uno de los pilares de un programa moderno de gestión de riesgos empresariales.

Registro de Proveedores Críticos

ID	Categoría	Servicio Prestado	Criticidad
PC-001	Energía	Suministro eléctrico	Crítica
PC-002	Telecomunicaciones	Internet y comunicaciones	Crítica
PC-003	Seguridad Física	Vigilancia	Crítica
PC-004	Limpieza	Higiene	Alta
PC-005	Mantenimiento	Infraestructura	Alta
PC-006	Ascensores	Mantenimiento especializado	Alta
PC-007	Escaleras Mecánicas	Soporte técnico	Alta
PC-008	Parking	Sistemas operativos	Alta
PC-009	Tecnología	Soporte TI	Crítica
PC-010	CCTV	Mantenimiento del sistema	Alta
PC-011	Climatización	HVAC	Alta
PC-012	Gestión de Residuos	Servicios ambientales	Media
PC-013	Servicios Médicos	Atención de emergencias	Alta
PC-014	Instituciones Financieras	Servicios bancarios	Alta
PC-015	Seguros	Cobertura de riesgos	Alta

5.22 Resumen General de Activos

Como resultado del proceso de identificación y clasificación realizado durante el presente capítulo, se obtuvo el siguiente inventario consolidado de activos.

Categoría	Cantidad Aproximada
Activos Físicos	25
Activos Tecnológicos	35

Activos de Información	15
Activos Humanos	15
Servicios Críticos	15
Proveedores Críticos	15

Total de Activos Evaluados

120 Activos

5.23 Distribución por Nivel de Criticidad

Nivel	Cantidad
Crítica	38
Alta	54
Media	22
Baja	6

Se observa que aproximadamente el **77 %** de los activos identificados presentan una criticidad **Alta o Crítica**, lo que refleja la elevada dependencia del centro comercial respecto de la infraestructura física, tecnológica y de servicios que soportan la operación diaria.

5.24 Principales Observaciones

Del análisis realizado se desprenden las siguientes observaciones:

- La operación presenta una elevada dependencia de activos tecnológicos para sostener procesos administrativos, comerciales y de seguridad.

- La infraestructura física constituye un componente crítico para garantizar la continuidad de las operaciones y la seguridad de clientes y colaboradores.
- Los servicios esenciales, como energía eléctrica, conectividad, videovigilancia y control de accesos, representan puntos de alta criticidad cuyo funcionamiento continuo resulta indispensable.
- La dependencia de proveedores externos incrementa la necesidad de establecer procesos formales de gestión de terceros y continuidad de servicios.
- Los activos de información requieren mecanismos adecuados de clasificación, protección y respaldo para preservar su confidencialidad, integridad y disponibilidad.
- La gestión de personas continúa siendo un elemento clave dentro de la estrategia de ciberseguridad, particularmente frente a amenazas relacionadas con ingeniería social y error humano.

5.25 Conclusiones

Este inventario integra activos físicos, tecnológicos, de información, humanos y de proveedores, clasificados por criticidad (CIA). Los activos Críticos y Altos son la base para el análisis de amenazas y vulnerabilidades de los capítulos siguientes.

6. Identificación de Amenazas

6.1 Introducción

Este capítulo identifica las amenazas que podrían afectar la confidencialidad, integridad o disponibilidad de los activos del capítulo anterior.

Para el presente Assessment, las amenazas fueron clasificadas en cinco categorías principales:

- Amenazas Humanas
- Amenazas Tecnológicas
- Amenazas Operacionales
- Amenazas Ambientales
- Amenazas Físicas

La clasificación se realizó considerando estándares internacionales como ISO 27005, ISO 31000, NIST Cybersecurity Framework 2.0 y CIS Controls v8.

Nota metodológica: Las amenazas analizadas corresponden a escenarios de referencia contruidos con base en buenas prácticas y fuentes públicas.

6.2 Clasificación General de Amenazas

Categoría	Objetivo Principal
Humanas	Aprovechar errores o acciones de personas.
Tecnológicas	Comprometer sistemas, redes o información.
Operacionales	Interrumpir procesos críticos del negocio.
Ambientales	Afectar la infraestructura mediante eventos naturales o accidentales.
Físicas	Comprometer la seguridad de las instalaciones o personas.

6.3 Amenazas Humanas

Las amenazas humanas representan uno de los principales factores de riesgo para cualquier organización. En la actualidad, una parte significativa de los incidentes de ciberseguridad se originan a partir de errores humanos, campañas de ingeniería social o acciones maliciosas realizadas por personas con acceso autorizado.

En un entorno como un centro comercial, donde interactúan diariamente colaboradores, proveedores, locatarios y visitantes, este tipo de amenazas adquiere una relevancia particular.

INGENIERIA SOCIAL

La ingeniería social consiste en la manipulación psicológica de personas con el objetivo de obtener acceso a información, instalaciones o recursos de la organización.

Posibles impactos

- Obtención de credenciales.
- Acceso no autorizado.
- Divulgación de información sensible.

- Compromiso de procesos administrativos.

PHISHING

El phishing continúa siendo uno de los vectores de ataque más utilizados por los ciberdelincuentes para comprometer organizaciones.

Consiste en el envío de comunicaciones fraudulentas que buscan engañar al usuario para revelar información confidencial o ejecutar software malicioso.

Posibles impactos

- Robo de credenciales.
- Compromiso de cuentas corporativas.
- Acceso inicial para ransomware.
- Fraude financiero.

FRAUDE

Las organizaciones del sector retail pueden ser objetivo de diferentes modalidades de fraude interno y externo.

Entre ellas:

- Fraude financiero.
- Fraude mediante proveedores.
- Manipulación de procesos administrativos.
- Suplantación de identidad.

Posibles impactos

- Pérdidas económicas.
- Daño reputacional.
- Interrupción de procesos.
- Conflictos legales.

INSIDER THREAT

Las amenazas internas corresponden a acciones realizadas por colaboradores, contratistas o terceros con acceso autorizado que, de manera intencional o accidental, comprometen los activos de la organización.

Ejemplos

- Uso indebido de privilegios.
- Robo de información.
- Eliminación de datos.
- Configuraciones incorrectas.
- Divulgación accidental de información.

Nivel de Riesgo Estimado

Alto

6.4 Amenazas Tecnológicas

La creciente digitalización de los procesos comerciales incrementa la exposición frente a amenazas tecnológicas capaces de afectar tanto la operación diaria como la continuidad del negocio.

MALWARE

El malware comprende cualquier software diseñado para alterar, dañar o comprometer sistemas informáticos.

Posibles consecuencias

- Pérdida de información.
- Interrupción de servicios.
- Compromiso de estaciones de trabajo.
- Movimiento lateral dentro de la red.

Nivel de Riesgo Estimado

Alto

RANSOMWARE

El ransomware representa actualmente una de las amenazas más relevantes para organizaciones de todos los sectores.

Su objetivo consiste en cifrar información crítica para posteriormente exigir un pago por su recuperación.

Posibles impactos

- Interrupción total de operaciones.
- Indisponibilidad de sistemas.
- Pérdida financiera.
- Daño reputacional.
- Activación de planes de continuidad.

Nivel de Riesgo Estimado

Crítico

ATAQUES DE DENEGACIÓN DE SERVICIO (DDoS)

Los ataques DDoS buscan saturar servicios tecnológicos hasta provocar su indisponibilidad.

Aunque afectan principalmente servicios expuestos a Internet, también pueden impactar procesos administrativos y canales digitales.

Posibles consecuencias

- Caída de servicios.
- Interrupción de comunicaciones.
- Pérdida de disponibilidad.

Nivel de Riesgo Estimado

Medio-Alto

EXPLOTACIÓN DE VULNERABILIDADES

La existencia de software desactualizado o configuraciones inseguras puede permitir que un atacante obtenga acceso no autorizado mediante la explotación de vulnerabilidades conocidas.

Posibles impactos

- Acceso remoto.
- Escalada de privilegios.
- Robo de información.
- Instalación de malware.

Nivel de Riesgo Estimado

Alto

6.5 Amenazas Operacionales

Las amenazas operacionales comprenden aquellos eventos que afectan directamente la continuidad del negocio sin involucrar necesariamente actividades maliciosas.

CORTE DE ENERGÍA

La interrupción del suministro eléctrico puede afectar simultáneamente infraestructura tecnológica, sistemas de seguridad, estacionamientos y operaciones comerciales.

Impactos

- Caída de sistemas.
- Interrupción del parking.
- Afectación de CCTV.
- Suspensión temporal de actividades.

Nivel de Riesgo

Alto

INTERRUPCIÓN DE SERVICIO DE INTERNET

La indisponibilidad de conectividad puede afectar múltiples procesos administrativos y tecnológicos.

Impactos

- Pérdida de comunicaciones.
- Interrupción de servicios digitales.
- Limitaciones operativas.

Nivel de Riesgo

Alto

FALLA DEL SISTEMA DE PARKING

El estacionamiento constituye uno de los servicios críticos del centro comercial.

Su indisponibilidad podría afectar el ingreso y egreso de clientes, generando impactos operativos y reputacionales.

Nivel de Riesgo

Alto

CAÍDA DE SISTEMAS ADMINISTRATIVOS

La indisponibilidad de aplicaciones utilizadas por las áreas administrativas puede afectar significativamente la operación diaria.

Impactos

- Retrasos operativos.
- Interrupción de procesos.
- Pérdida temporal de productividad.

Nivel de Riesgo

Alto

6.6 Amenazas Ambientales

Los eventos ambientales representan riesgos cuya ocurrencia escapa al control de la organización, pero cuyos efectos pueden mitigarse mediante planes adecuados de continuidad y recuperación.

INCENDIO

Un incendio puede generar daños severos sobre infraestructura física, sistemas tecnológicos y seguridad de las personas.

Posibles impactos

- Pérdida de infraestructura.
- Interrupción total de operaciones.
- Evacuación del edificio.
- Activación del plan de emergencia.

Nivel de Riesgo

Crítico

Inundación

Dependiendo de la ubicación de las instalaciones, una inundación puede afectar áreas técnicas, estacionamientos y sistemas eléctricos.

Impactos

- Daños a infraestructura.
- Pérdida de equipamiento.
- Interrupción operativa.

Nivel de Riesgo

Medio

TORMENTAS

Eventos meteorológicos severos pueden afectar el suministro eléctrico, las comunicaciones y la infraestructura del edificio.

Nivel de Riesgo

Medio

6.7 Amenazas Físicas

La seguridad física constituye un componente esencial dentro del modelo de gestión de riesgos.

INTRUSIÓN

El acceso físico no autorizado a áreas restringidas puede comprometer activos tecnológicos, información y procesos críticos.

Posibles impactos

- Robo de información.
- Sabotaje.
- Daños a infraestructura.
- Acceso a sistemas.

Nivel de Riesgo

Alto

ROBO

El robo de equipos, documentación o activos tecnológicos puede afectar tanto la continuidad operativa como la seguridad de la información.

Nivel de Riesgo

Alto

VANDALISMO

Los actos de vandalismo pueden ocasionar daños materiales, interrupción de servicios y afectación a la imagen institucional.

Nivel de Riesgo

Medio

6.8 Matriz Resumen de Amenazas

Categoría	Cantidad de Amenazas	Nivel de Exposición
Humanas	4	Alto
Tecnológicas	4	Crítico
Operacionales	4	Alto
Ambientales	3	Medio
Físicas	3	Alto

6.9 Observaciones Generales

Del análisis realizado se observa que las amenazas tecnológicas y humanas representan la mayor exposición potencial para un entorno de shopping center, debido a la elevada dependencia de sistemas de información, servicios digitales y procesos administrativos soportados por infraestructura tecnológica.

Asimismo, las amenazas operacionales y físicas presentan un impacto significativo sobre la continuidad del negocio, especialmente cuando afectan servicios esenciales como energía eléctrica, comunicaciones, estacionamientos, videovigilancia y control de accesos.

Los eventos ambientales, si bien presentan una probabilidad menor en comparación con otras categorías, poseen la capacidad de generar consecuencias severas sobre la infraestructura y la continuidad operativa, justificando la necesidad de contar con planes de continuidad del negocio y recuperación ante desastres.

6.10 Conclusiones

El centro comercial está expuesto a amenazas humanas, tecnológicas, operacionales, ambientales y físicas. El siguiente capítulo analiza las vulnerabilidades que facilitarían su materialización.

7. Identificación de Vulnerabilidades (Gap Analysis)

7.1 Introducción

Una vulnerabilidad es una debilidad que una amenaza puede explotar, aumentando el riesgo de un incidente.

En el marco del presente Assessment, la identificación de vulnerabilidades fue realizada mediante un enfoque de análisis de brechas (Gap Analysis), comparando el escenario de referencia construido para este caso de estudio con las mejores prácticas definidas por:

- ISO/IEC 27001:2022
- ISO 31000:2018
- NIST Cybersecurity Framework 2.0
- CIS Controls Version 8

Nota metodológica: Las vulnerabilidades identificadas representan escenarios potenciales elaborados con base en información pública y supuestos metodológicos.

7.2 Objetivo del Gap Analysis

El objetivo principal consiste en identificar posibles oportunidades de mejora relacionadas con la gestión de la seguridad de la información y la continuidad operativa.

Las vulnerabilidades identificadas serán utilizadas como insumo para la construcción de la matriz de riesgos presentada en el siguiente capítulo.

7.3 Criterios de Evaluación

Cada vulnerabilidad fue evaluada considerando los siguientes factores:

- Probabilidad de explotación.
- Impacto potencial sobre la operación.
- Impacto económico.
- Impacto reputacional.
- Afectación sobre la continuidad del negocio.
- Facilidad de implementación de controles.
- Nivel de prioridad para su tratamiento.

7.4 Registro de Vulnerabilidades (Gap Analysis)

ID	Vulnerabilidad	Riesgo Asociado	Impacto	Prioridad
V-001	Posible ausencia de MFA para accesos críticos (<i>supuesto</i>)	Compromiso de cuentas	Alto	Alta
V-002	Inventario de activos potencialmente incompleto	Activos sin protección adecuada	Alto	Alta
V-003	Clasificación insuficiente de la información	Exposición de datos	Alto	Alta
V-004	Dependencia elevada de proveedores externos	Riesgo operacional	Alto	Alta
V-005	Programa de concientización no evidenciado (<i>supuesto</i>)	Ingeniería social	Alto	Alta
V-006	Gestión documental descentralizada	Pérdida de información	Medio	Media
V-007	Gestión de accesos privilegiados no verificada	Escalada de privilegios	Alto	Alta

V-008	Proceso de revisión de accesos no evidenciado	Accesos indebidos	Alto	Alta
V-009	Gestión de vulnerabilidades no evidenciada	Explotación de software	Alto	Alta
V-010	Segmentación de red no verificable	Movimiento lateral	Alto	Alta
V-011	Monitoreo continuo de eventos no evidenciado	Detección tardía	Alto	Alta
V-012	Plan formal de respuesta a incidentes no evidenciado	Mayor tiempo de recuperación	Alto	Alta
V-013	Plan de Continuidad del Negocio no verificable	Interrupción prolongada	Crítico	Crítica
V-014	Plan de Recuperación ante Desastres no verificable	Recuperación lenta	Crítico	Crítica
V-015	Dependencia de energía eléctrica	Interrupción operativa	Alto	Alta
V-016	Dependencia de Internet	Caída de procesos	Alto	Alta
V-017	Gestión de cambios no evidenciada	Errores operativos	Medio	Media
V-018	Gestión de configuraciones no verificada	Configuraciones inseguras	Alto	Alta
V-019	Hardening de servidores no verificable	Ataques exitosos	Alto	Alta
V-020	Política de backups no verificable	Pérdida permanente de datos	Crítico	Crítica
V-021	Pruebas de restauración no verificables	Backups inutilizables	Crítico	Crítica
V-022	Gestión de parches no evidenciada	Vulnerabilidades explotables	Alto	Alta
V-023	Evaluaciones periódicas de riesgo no evidenciadas	Riesgos desconocidos	Medio	Media

V-02 4	Gestión de terceros parcialmente dependiente	Riesgos de cadena de suministro	Alto	Alta
V-02 5	Controles de acceso físico múltiples	Intrusión	Alto	Alta
V-02 6	Posible ausencia de monitoreo 24/7 del SOC (<i>supuesto</i>)	Respuesta tardía	Medio	Media
V-02 7	Ausencia de indicadores de ciberseguridad (KPIs)	Baja visibilidad	Medio	Media
V-02 8	Inventario tecnológico potencialmente desactualizado	Gestión deficiente	Medio	Media
V-02 9	Gestión de cuentas inactivas no verificable	Accesos indebidos	Alto	Alta
V-03 0	Política de contraseñas no verificable	Robo de credenciales	Alto	Alta

7.5 Clasificación por Dominio

Gobernanza

- Inventario de activos.
- Gestión documental.
- Gestión de riesgos.
- Gestión de proveedores.
- Indicadores.

Gestión de Identidades

- MFA.
- Cuentas privilegiadas.
- Revisión de accesos.
- Contraseñas.
- Cuentas inactivas.

Infraestructura Tecnológica

- Segmentación.
- Hardening.
- Gestión de parches.
- Configuraciones.
- Vulnerabilidades.

Continuidad del Negocio

- BCP.
- DRP.
- Backups.
- Restauración.
- Energía.
- Internet.

Seguridad Física

- Accesos.
- CCTV.
- Áreas restringidas.

Operaciones

- Monitoreo.
- Gestión de incidentes.
- Gestión de cambios.

7.6 Distribución de Vulnerabilidades

Dominio	Cantidad
Gobernanza	6
Gestión de Identidades	5
Infraestructura Tecnológica	7
Continuidad del Negocio	6

Seguridad Física	3
Operaciones	3

7.7 Principales Brechas Identificadas

El análisis realizado permite identificar diversas áreas donde, desde una perspectiva metodológica, podrían existir oportunidades de mejora si no se encontraran implementados determinados controles de seguridad. Entre las brechas con mayor impacto potencial se destacan:

- La posible ausencia de autenticación multifactor para accesos críticos, lo que incrementaría el riesgo de compromiso de cuentas mediante ataques de phishing o robo de credenciales.
- La falta de evidencia sobre procesos formales de gestión de vulnerabilidades y aplicación de parches, aumentando la exposición frente a amenazas que explotan software desactualizado.
- La inexistencia verificable de planes de Continuidad del Negocio (BCP) y Recuperación ante Desastres (DRP), fundamentales para reducir el impacto de incidentes mayores.
- La ausencia de información que permita confirmar la realización de pruebas periódicas de restauración de respaldos, un aspecto clave para garantizar la recuperación efectiva ante eventos disruptivos.
- La dependencia de proveedores críticos para servicios esenciales, lo que resalta la importancia de fortalecer la gestión de riesgos de terceros.
- La necesidad de contar con programas continuos de concientización en ciberseguridad para mitigar amenazas de ingeniería social y error humano.

Estas observaciones no representan hallazgos confirmados, sino escenarios de referencia utilizados para desarrollar el modelo de riesgos del presente caso de estudio.

7.8 Conclusiones

Las principales oportunidades de mejora están en gobernanza, gestión de identidades, continuidad del negocio y gestión de terceros. Estas vulnerabilidades, cruzadas con las amenazas del capítulo anterior, forman la matriz de riesgos del siguiente capítulo.

8. Evaluación de Riesgos

8.1 Introducción

Este capítulo evalúa cada riesgo según su probabilidad e impacto, para priorizar el tratamiento y la asignación de recursos.

El presente análisis fue desarrollado siguiendo un enfoque cualitativo basado en riesgos, ampliamente utilizado en proyectos de consultoría y alineado con los principios establecidos por las normas ISO 31000:2018, ISO/IEC 27005:2022, ISO/IEC 27001:2022 y el NIST Cybersecurity Framework 2.0.

8.2 Objetivo de la Evaluación

La evaluación de riesgos tiene como finalidad determinar el nivel de criticidad asociado a cada escenario identificado durante el Assessment, considerando la relación existente entre:

- Activos.
- Amenazas.
- Vulnerabilidades.
- Probabilidad de ocurrencia.
- Impacto potencial.

El resultado permitirá priorizar las acciones de tratamiento del riesgo y definir estrategias orientadas a reducir la exposición de la organización.

8.3 Metodología de Evaluación

Para el desarrollo del presente Assessment se adoptó una metodología cualitativa basada en la combinación de dos variables principales:

- **Probabilidad (Likelihood):** posibilidad de que una amenaza explote una vulnerabilidad existente.
- **Impacto (Impact):** consecuencias que tendría la materialización del riesgo sobre la organización.

Cada riesgo fue evaluado utilizando una escala numérica de cinco niveles para ambas variables.

Posteriormente, se calculó el nivel de riesgo mediante una matriz de probabilidad e impacto, clasificando cada escenario en uno de los siguientes niveles:

- Bajo
- Medio
- Alto
- Crítico

Este enfoque permite comparar objetivamente diferentes escenarios de riesgo y establecer prioridades de mitigación.

8.4 Escala de Probabilidad

La probabilidad representa la posibilidad de que un evento ocurra dentro del contexto operacional analizado.

Valor	Nivel	Descripción
1	Muy Baja	Escenario poco probable o excepcional.
2	Baja	Evento poco frecuente.
3	Media	Puede ocurrir ocasionalmente.
4	Alta	Es probable que ocurra.
5	Muy Alta	Alta probabilidad de ocurrencia.

Factores considerados

- Nivel de exposición.
- Existencia de vulnerabilidades.
- Motivación del atacante.
- Historial del sector.
- Dependencia tecnológica.
- Complejidad del entorno.

8.5 Escala de Impacto

El impacto representa la magnitud de las consecuencias derivadas de la materialización de un riesgo.

Valor	Nivel	Descripción
1	Insignificante	Impacto mínimo sobre la operación.
2	Menor	Afectación limitada y fácilmente recuperable.

3	Moderado	Interrupción parcial de procesos.
4	Alto	Afectación significativa del negocio.
5	Crítico	Interrupción severa de la continuidad operativa.

Durante la evaluación se consideraron los siguientes tipos de impacto:

- Impacto Operacional.
- Impacto Financiero.
- Impacto Legal.
- Impacto Regulatorio.
- Impacto Reputacional.
- Impacto sobre la Seguridad de la Información.
- Impacto sobre la Continuidad del Negocio.

8.6 Fórmula de Evaluación del Riesgo

El nivel de riesgo fue calculado utilizando la siguiente expresión:

$$\text{Nivel de Riesgo} = \text{Probabilidad} \times \text{Impacto}$$

Donde:

Probabilidad representa la posibilidad de ocurrencia del evento.

Impacto representa la severidad de las consecuencias sobre la organización.

El resultado permite clasificar el riesgo dentro de la matriz definida para el presente Assessment.

Ejemplo de cálculo

Riesgo	Probabilidad	Impacto	Resultado
Phishing	4	4	16
Corte de Energía	3	5	15
Ransomware	5	5	25

8.7 Clasificación del Nivel de Riesgo

Con base en el resultado obtenido, los riesgos fueron clasificados según la siguiente escala.

Resultado	Nivel
1 – 5	Bajo
6 – 10	Medio
11 – 15	Alto
16 – 25	Crítico

Esta clasificación facilita la priorización de los esfuerzos de mitigación y la asignación de recursos.

8.8 Criterios de Aceptación del Riesgo

No todos los riesgos requieren el mismo tratamiento. En función del nivel obtenido, la organización puede adoptar distintas estrategias.

Nivel	Tratamiento recomendado
Bajo	Aceptar y monitorear.
Medio	Implementar controles cuando resulte conveniente.
Alto	Mitigar mediante controles específicos.
Crítico	Tratamiento inmediato y seguimiento por la Dirección.

La aceptación del riesgo deberá ser autorizada por la Alta Dirección, considerando el apetito y la tolerancia al riesgo definidos por la organización.

8.9 Opciones de Tratamiento del Riesgo

De acuerdo con ISO 31000 e ISO/IEC 27005, cada riesgo puede ser tratado mediante una de las siguientes estrategias:

Mitigar

Implementar controles para reducir la probabilidad o el impacto del riesgo.

Transferir

Trasladar parte del riesgo a un tercero mediante seguros, contratos o acuerdos de nivel de servicio (SLA).

Evitar

Eliminar la actividad o proceso que origina el riesgo.

Aceptar

Aceptar formalmente el riesgo cuando su nivel sea compatible con el apetito de riesgo de la organización.

La selección de la estrategia dependerá del análisis costo-beneficio y de las prioridades estratégicas definidas por la dirección.

8.10 Riesgo Inherente y Riesgo Residual

El presente Assessment distingue entre dos conceptos fundamentales:

Riesgo Inherente

Corresponde al nivel de riesgo existente antes de la implementación de controles.

Representa la exposición inicial del activo frente a una amenaza determinada.

Riesgo Residual

Corresponde al nivel de riesgo que permanece luego de aplicar controles preventivos, detectivos y correctivos.

El objetivo de la gestión de riesgos consiste en reducir el riesgo inherente hasta alcanzar un nivel residual aceptable para la organización.

8.11 Principios Utilizados Durante la Evaluación

La evaluación realizada se apoyó en los siguientes principios metodológicos:

- Enfoque basado en riesgos.
- Protección de los activos críticos.
- Priorización según impacto para el negocio.
- Evaluación objetiva y reproducible.
- Consideración del contexto organizacional.
- Alineación con estándares internacionales.
- Trazabilidad entre activos, amenazas y vulnerabilidades.
- Orientación hacia la mejora continua.

Estos principios permiten que la metodología utilizada sea consistente con los modelos de gestión de riesgos empleados por organizaciones de distintos sectores y tamaños.

8.12 Conclusiones

Esta metodología permite comparar los riesgos de forma objetiva y da base al Risk Register del capítulo siguiente.

9. Matriz de Riesgos

9.1 Introducción

Con los activos, amenazas y vulnerabilidades ya identificados, esta matriz consolida y prioriza los riesgos según su probabilidad e impacto.

Para el presente Assessment se desarrolló un Registro de Riesgos (Risk Register) que consolida los escenarios de riesgo más relevantes identificados durante el análisis, utilizando la metodología presentada en el capítulo anterior.

9.2 Criterios de Clasificación

Cada riesgo fue evaluado considerando los siguientes elementos:

- Activo afectado.
- Amenaza asociada.
- Vulnerabilidad relacionada.
- Probabilidad de ocurrencia.
- Impacto potencial.
- Nivel de riesgo inherente.

La combinación entre probabilidad e impacto permitió clasificar cada riesgo dentro de una de las siguientes categorías:

Nivel	Puntaje	Tratamiento
Bajo	1 - 5	Monitorear
Medio	6 - 10	Mitigar cuando sea posible
Alto	11 - 15	Implementar controles prioritarios
Crítico	16 - 25	Tratamiento inmediato

9.3 Registro de Riesgos (Risk Register)

ID	Riesgo	Activo Principal	Amenaza	Vulnerabilidad	Prob.	Impacto	Nivel
R-001	Compromiso de cuentas corporativas	Correo Corporativo	Phishing	Posible ausencia de MFA	4	4	Crítico
R-002	Ataque de Ransomware	Infraestructura TI	Malware	Gestión de parches	5	5	Crítico
R-003	Interrupción por corte eléctrico	Infraestructura Física	Corte de energía	Dependencia energética	3	5	Alto
R-004	Acceso físico no autorizado	Oficinas	Intrusión	Múltiples accesos	3	4	Alto

R-005	Robo de credenciales	Usuarios	Ingeniería Social	Oportunidad de mejora en awareness	4	4	Crítico
R-006	Caída del sistema de Parking	Parking	Falla Operacional	Dependencia tecnológica	3	4	Alto
R-007	Pérdida de conectividad	Red Corporativa	Caída ISP	Dependencia proveedor	3	4	Alto
R-008	Fuga de información	Documentación	Insider Threat	Gestión documental	3	5	Alto
R-009	Robo de equipos	Equipos TI	Robo	Controles físicos	2	4	Medio
R-010	Explotación de vulnerabilidades	Servidores	Ciberataque	Parches pendientes	4	5	Crítico
R-011	Caída del CCTV	Seguridad Física	Falla técnica	Oportunidad de mejora en monitoreo	3	4	Alto
R-012	Incendio	Edificio	Incendio	Infraestructura	2	5	Medio
R-013	Inundación	Subsuelo	Evento ambiental	Infraestructura	2	4	Medio
R-014	Ataque DDoS	Servicios Web	DDoS	Protección insuficiente	3	4	Alto
R-015	Error humano	Administración	Error Operativo	Capacitación	4	3	Alto
R-016	Falla de Backups	Información	Error Técnico	Restauración no validada	4	5	Crítico
R-017	Acceso privilegiado indebido	Dominio	Insider	Gestión de privilegios	3	5	Alto
R-018	Compromiso de proveedores	Servicios	Supply Chain	Gestión de terceros	3	4	Alto
R-019	Sabotaje interno	Infraestructura	Insider Threat	Accesos privilegiados	2	5	Medio

R-020	Malware en estaciones	PCs	Malware	Antivirus	4	3	Alto
R-021	Falla de UPS	Data Room	Operacional	Equipamiento	2	4	Medio
R-022	Caída del correo	Correo	Falla TI	Dependencia tecnológica	3	4	Alto
R-023	Pérdida documental	Documentación	Error Humano	Gestión documental	2	3	Medio
R-024	Ataque a WiFi	Red WiFi	Intrusión	Configuración	3	3	Medio
R-025	Interrupción administrativa	Sistemas	Falla Aplicativa	Gestión de cambios	3	4	Alto

9.4 Resumen Estadístico de Riesgos

Como resultado del análisis realizado, se obtuvo la siguiente distribución:

Nivel	Cantidad	Porcentaje
Crítico	5	20 %
Alto	13	52 %
Medio	7	28 %
Bajo	0	0 %

Se observa que **18 de los 25 riesgos identificados (72%)** presentan un nivel **Alto o Crítico**, lo que evidencia la necesidad de implementar medidas orientadas a fortalecer la resiliencia operativa y la postura de ciberseguridad.

9.5 Matriz de Riesgos (Heat Matrix)

La siguiente matriz representa gráficamente la distribución de los riesgos identificados según su probabilidad e impacto.

Impacto/Probabilidad	Muy Baja	Baja	Media	Alta	Muy Alta
Crítico	–	R-12, R-19 (Riesgo: 10)	R-03, R-08, R-17 (Riesgo: 15)	R-10, R-16 (Riesgo: 20)	R-02 (Riesgo: 25)
Alto		R-09, R-13,	R-04, R-06, R-07, R-11, R-14,	R-01, R-05	

	–	R-21 <i>(Riesgo: 8)</i>	R-18, R-22, R-25 <i>(Riesgo: 12)</i>	<i>(Riesgo: 16)</i>	–
Medio	–	R-23 <i>(Riesgo: 6)</i>	R-24 <i>(Riesgo: 9)</i>	R-15, R-20 <i>(Riesgo: 12)</i>	–
Bajo	–	–	–	–	–
Muy Bajo	–	–	–	–	–

Nota: El detalle completo de los 15 riesgos de mayor criticidad, junto con su representación gráfica ejecutiva, se presenta en el Capítulo 11 (Heat Map Ejecutivo).

Leyenda y Criterios de Acción de la Matriz

Color	Nivel de Riesgo	Rangos de Puntaje	Acción Requerida (Criterio de Aceptación)
 Rojo	Crítico	15 - 25	Mitigación Inmediata: Requiere atención urgente de la alta gerencia. Se deben implementar controles de seguridad en un plazo menor a 30 días y monitorear continuamente. El riesgo no es aceptable.

 Naranja	Alto	12	Mitigación Prioritaria: Requiere desarrollo de planes de acción formalizados en el corto plazo (menos de 60 días). Se deben asignar responsables específicos para el diseño de nuevas salvaguardas.
 Amarillo	Moderado	8 - 10	Monitoreo Preventivo: Se deben revisar los controles existentes en el mediano plazo (90-180 días) para asegurar que el riesgo no escale. Es tolerable bajo supervisión periódica.
 Verde	Bajo	1 - 6	Riesgo Aceptado: El nivel de riesgo es tolerable para la operación del shopping. Se mantiene bajo observación en las revisiones anuales de seguridad sin requerir inversión inmediata.

9.6 Observaciones del Análisis

La evaluación realizada evidencia que la mayor concentración de riesgos se encuentra asociada a la infraestructura tecnológica, la gestión de identidades, la continuidad del negocio y la dependencia de servicios críticos.

Los escenarios con mayor nivel de criticidad corresponden a ataques de ransomware, compromiso de credenciales, explotación de vulnerabilidades, fallas en los mecanismos de respaldo y otros eventos capaces de afectar simultáneamente la disponibilidad de múltiples procesos de negocio.

Asimismo, los riesgos clasificados como **Altos** reflejan la importancia de fortalecer los controles preventivos relacionados con la gestión de proveedores, el mantenimiento de infraestructura, la concientización del personal y la protección de los sistemas tecnológicos.

9.7 Conclusiones

El 72% de los riesgos identificados son Altos o Críticos, lo que justifica un plan de tratamiento inmediato. El próximo capítulo presenta el Heat Map y el detalle de los 15 riesgos prioritarios.

10. Top 15 Riesgos Prioritarios

Introducción

La información presentada constituye una propuesta de tratamiento de riesgos elaborada con fines académicos y de desarrollo profesional, y no representa una auditoría oficial ni una evaluación autorizada.

Estos son los 15 riesgos de mayor impacto potencial sobre la continuidad del negocio, analizados individualmente con su probabilidad, impacto y recomendaciones.

Riesgo R-001 – Ataque de Ransomware

Campo	Detalle
ID	R-001
Categoría	Tecnológico
Nivel de Riesgo	Crítico
Probabilidad	5
Impacto	5
Riesgo Inherente	25
Prioridad	Muy Alta
Responsable sugerido	Gerencia de Tecnología
Tiempo recomendado	90 días

Activos afectados

- Infraestructura tecnológica
- Servidores
- Equipos de usuario
- Información corporativa
- Servicios críticos

Descripción

Un ataque de ransomware podría cifrar información crítica utilizada para la operación diaria del centro comercial, provocando la indisponibilidad de sistemas administrativos, financieros, operativos y tecnológicos.

Escenario

Un colaborador recibe un correo fraudulento con un archivo malicioso. Al ejecutarlo, el malware se propaga por la red comprometiendo múltiples activos tecnológicos.

Impacto para el negocio

- Interrupción de operaciones.
- Pérdidas económicas.
- Afectación reputacional.
- Posible pérdida de información.
- Activación del plan de continuidad.

Controles existentes (Supuestos)

- Antivirus corporativo.
- Generadores eléctricos.
- Controles básicos de acceso.

Brechas identificadas

- Gestión de vulnerabilidades no evidenciada.
- Pruebas de restauración no verificadas.
- Programa de awareness no evidenciado.

Controles recomendados

- Implementar EDR/XDR.
- MFA para accesos críticos.
- Segmentación de red.
- Backups offline.
- Simulaciones de ransomware.
- Programa continuo de concientización.

Marcos de referencia

- ISO 27001
- ISO 27002
- NIST CSF
- CIS Controls 4, 7, 10 y 11

Costo estimado

Alto

Beneficio esperado

Reducción significativa del riesgo de indisponibilidad de sistemas críticos.

****Nota de Contexto GRC:**** Se asigna una probabilidad máxima (5) debido al incremento exponencial de ataques dirigidos al sector Retail y centros comerciales en Latinoamérica, donde la interconexión con sistemas de proveedores externos (Supply Chain) amplía significativamente la superficie de ataque expositiva.

Riesgo R-002 – Compromiso de Credenciales mediante Phishing

Campo	Detalle
ID	R-002
Categoría	Humana
Nivel	Crítico
Probabilidad	4
Impacto	4
Riesgo Inherente	16
Prioridad	Muy Alta
Responsable	Tecnología / RRHH
Tiempo	60 días

Activos afectados

- Correo electrónico.
- Usuarios corporativos.
- Sistemas administrativos.

Descripción

Las campañas de phishing continúan siendo uno de los principales vectores de acceso inicial utilizados por ciberdelincuentes.

Escenario

Un usuario introduce sus credenciales en un sitio falso, permitiendo el acceso no autorizado a servicios corporativos.

Impacto

- Robo de información.
- Fraude.
- Acceso remoto.
- Escalada de privilegios.

Controles existentes

- Filtros básicos de correo.
- Políticas de contraseña.

Brechas

- MFA no verificada.
- Awareness no evidenciado.
- Simulaciones de phishing no verificadas.

Recomendaciones

- Implementar MFA.
- Capacitación continua.
- Simulaciones periódicas.
- Protección avanzada del correo.
- Monitoreo de accesos.

Marcos

- ISO 27001
- NIST CSF
- CIS Controls 5 y 14

Costo

Medio

Beneficio

Disminución significativa del riesgo de compromiso de cuentas.

Riesgo R-003 – Interrupción de Servicios por Corte de Energía

Campo	Detalle
ID	R-003
Categoría	Operacional
Nivel	Alto
Probabilidad	3
Impacto	5
Riesgo	15
Prioridad	Alta
Responsable	Mantenimiento

Activos afectados

- Energía.
- CCTV.
- Parking.
- Sistemas administrativos.
- Redes.

Descripción

La interrupción del suministro eléctrico puede afectar simultáneamente múltiples procesos críticos.

Escenario

Una falla prolongada en el suministro genera indisponibilidad parcial de servicios esenciales.

Impacto

- Caída de sistemas.
- Demoras operativas.
- Interrupción de servicios.

Controles existentes

- Generadores eléctricos.

Brechas

- Pruebas periódicas no verificadas.
- Procedimientos de contingencia no evidenciados.

Recomendaciones

- Ensayos trimestrales.
- Procedimientos documentados.
- Inventario de autonomía.
- Plan de continuidad.

Marcos

- ISO 22301
- ISO 31000

Costo

Medio

Beneficio

Mayor resiliencia operacional.

Riesgo R-004 – Acceso Físico No Autorizado

Campo	Detalle
ID	R-004
Categoría	Física
Nivel	Alto
Probabilidad	3
Impacto	4
Riesgo	12
Prioridad	Alta
Responsable	Seguridad Física

Activos afectados

- Oficinas.
- Tecnología.
- Información.
- Equipamiento.

Descripción

La existencia de múltiples accesos incrementa la superficie de exposición frente a intentos de intrusión.

Escenario

Una persona accede a un área restringida aprovechando controles insuficientes.

Impacto

- Robo.
- Sabotaje.
- Acceso a información.
- Interrupción operativa.

Controles existentes

- Vigilancia.
- CCTV.
- Seguridad física.

Brechas

- Gestión de visitantes no verificada.
- Registro de accesos no evidenciado.

Recomendaciones

- Control electrónico de accesos.
- Credenciales temporales.
- Auditorías periódicas.
- Registro centralizado.

Marcos

ISO 27001

CIS Control 14

Costo

Medio

Beneficio

Reducción del riesgo de intrusión.

Riesgo R-005 – Compromiso de Proveedores Críticos

Campo	Detalle
ID	R-005
Categoría	Supply Chain
Nivel	Alto
Probabilidad	3
Impacto	4
Riesgo	12
Prioridad	Alta
Responsable	Administración / Tecnología

Activos afectados

- Servicios críticos.
- Tecnología.
- Comunicaciones.
- Infraestructura.

Descripción

La dependencia de proveedores externos puede generar interrupciones significativas cuando estos sufren incidentes de seguridad o fallas operativas.

Escenario

Un proveedor tecnológico experimenta una interrupción prolongada que impacta servicios esenciales del centro comercial.

Impacto

- Interrupción operativa.
- Demoras.
- Afectación de servicios al cliente.
- Riesgo reputacional.

Controles existentes

- Contratos comerciales.
- Relación con proveedores estratégicos.

Brechas

- Evaluaciones periódicas no verificadas.
- Gestión formal de riesgos de terceros no evidenciada.
- Planes de continuidad compartidos no verificados.

Controles recomendados

- Programa de Gestión de Riesgos de Terceros (TPRM).
- Evaluaciones periódicas de proveedores.
- Definición de SLA con requisitos de seguridad.
- Revisión anual de contratos.
- Planes de continuidad coordinados.

Marcos de referencia

- ISO 27001 (Gestión de proveedores).
- ISO 31000.
- NIST CSF – Govern.
- CIS Controls 15.

Costo estimado

Medio

Beneficio esperado

Mayor resiliencia de la cadena de suministro y reducción del riesgo asociado a terceros.

Riesgo R-006 – Falla del Sistema de Estacionamiento

Campo	Detalle
ID	R-006
Categoría	Operacional
Nivel de Riesgo	Alto
Probabilidad	3
Impacto	4
Riesgo Inherente	12
Prioridad	Alta
Responsable sugerido	Gerencia de Operaciones / Parking
Tiempo recomendado	90 días

Activos afectados

- Sistema de Parking.
- Barreras automáticas.
- Terminales de pago.
- Servidores del sistema.
- Atención al cliente.

Descripción

El sistema de estacionamiento constituye un servicio crítico para la operación del centro comercial. Una interrupción prolongada puede afectar el ingreso y egreso de vehículos, generar pérdidas económicas y afectar la experiencia del cliente.

Escenario

Una falla de software o hardware provoca la indisponibilidad del sistema de control de accesos al estacionamiento durante un período prolongado.

Impacto para el negocio

- Congestión vehicular.
- Pérdidas económicas.
- Reclamos de clientes.
- Interrupción parcial de la operación.

Controles existentes (Supuestos)

- Personal operativo.
- Procedimientos manuales básicos.
- Soporte técnico del proveedor.

Brechas identificadas

- Procedimientos alternativos no verificados.
- Alta dependencia tecnológica.
- Dependencia de proveedor externo.

Controles recomendados

- Procedimientos de contingencia documentados.
- Redundancia de servidores.
- Mantenimiento preventivo.
- Monitoreo continuo.
- Simulacros operativos.

Marcos de referencia

- ISO 22301
- ISO 31000
- NIST CSF – Recover

Costo estimado

Medio

Beneficio esperado

Mayor continuidad operativa y reducción de interrupciones del servicio.

Riesgo R-007 – Interrupción de la Conectividad a Internet

Campo	Detalle
ID	R-007
Categoría	Operacional
Nivel	Alto
Probabilidad	3
Impacto	4
Riesgo Inherente	12
Prioridad	Alta
Responsable	Tecnología

Activos afectados

- Red corporativa.
- Aplicaciones administrativas.
- Correo electrónico.
- Servicios digitales.

Descripción

La conectividad a Internet resulta esencial para el funcionamiento de múltiples procesos administrativos y tecnológicos.

Escenario

Una interrupción del proveedor de Internet afecta simultáneamente diversas áreas operativas.

Impacto

- Interrupción administrativa.
- Limitación de comunicaciones.
- Pérdida temporal de productividad.

Controles existentes

- Infraestructura de red.

Brechas

- Redundancia de enlaces no verificada.
- Procedimientos de contingencia no evidenciados.

Controles recomendados

- Doble proveedor de Internet.
- Balanceo de enlaces.
- Monitoreo de disponibilidad.
- Procedimientos de continuidad.

Marcos

- ISO 22301.
- NIST CSF.

Costo

Medio

Beneficio

Mayor disponibilidad de servicios críticos.

Riesgo R-008 – Fuga de Información Confidencial

Campo	Detalle
ID	R-008
Categoría	Información
Nivel	Alto
Probabilidad	3
Impacto	5
Riesgo Inherente	15
Prioridad	Muy Alta
Responsable	Administración / Tecnología

Activos afectados

- Documentación corporativa.
- Información financiera.
- Contratos.
- Datos de colaboradores.
- Información de proveedores.

Descripción

La divulgación no autorizada de información sensible puede generar consecuencias legales, financieras y reputacionales para la organización.

Escenario

Información confidencial es compartida accidentalmente o extraída por un actor interno o externo.

Impacto

- Incumplimiento normativo.
- Daño reputacional.
- Pérdidas económicas.
- Riesgos legales.

Controles existentes

- Controles básicos de acceso.
- Gestión documental.

Brechas

- Clasificación de información no verificada.
- DLP no evidenciado.
- Revisión periódica de permisos no verificada.

Controles recomendados

- Clasificación formal de información.
- Implementación de DLP.
- Cifrado de información sensible.
- Auditorías de acceso.
- Capacitación en manejo de información.

Marcos

- ISO 27001.
- ISO 27701.
- CIS Controls 3.

Costo

Alto

Beneficio

Reducción significativa del riesgo de exposición de información.

Riesgo R-009 – Ataque de Denegación de Servicio (DDoS)

Campo	Detalle
ID	R-009
Categoría	Tecnológica
Nivel	Alto
Probabilidad	3
Impacto	4
Riesgo Inherente	12
Prioridad	Alta
Responsable	Tecnología

Activos afectados

- Servicios expuestos a Internet.
- Sitio web.
- Servicios digitales.
- Comunicaciones.

Descripción

Un ataque DDoS busca saturar recursos tecnológicos para provocar la indisponibilidad de servicios.

Escenario

Un atacante genera un volumen masivo de tráfico sobre servicios expuestos.

Impacto

- Indisponibilidad.
- Interrupción de servicios.
- Reclamos de usuarios.
- Daño reputacional.

Controles existentes

- Infraestructura de red.

Brechas

- Protección DDoS no verificada.
- Monitoreo continuo no evidenciado.

Controles recomendados

- Servicio Anti-DDoS.
- WAF.
- Monitoreo 24/7.
- Procedimientos de respuesta.

Marcos

- NIST CSF.
- CIS Controls.

Costo

Medio

Beneficio

Mayor disponibilidad de servicios públicos.

Riesgo R-010 – Compromiso de Infraestructura Tecnológica por Vulnerabilidades

Campo	Detalle
ID	R-010
Categoría	Tecnológica
Nivel	Crítico
Probabilidad	4
Impacto	5
Riesgo Inherente	20
Prioridad	Muy Alta
Responsable	Gerencia de Tecnología

Activos afectados

- Servidores.
- Equipos de red.
- Switches.
- Routers.
- Sistemas administrativos.

Descripción

La existencia de vulnerabilidades conocidas sin remediar puede permitir el acceso no autorizado a sistemas críticos.

Escenario

Un atacante explota una vulnerabilidad publicada para obtener acceso a la infraestructura tecnológica.

Impacto

- Compromiso de sistemas.
- Robo de información.
- Movimiento lateral.
- Interrupción de operaciones.

Controles existentes

- Controles básicos de infraestructura.

Brechas

- Gestión de vulnerabilidades no evidenciada.
- Hardening no verificable.
- Gestión de parches no confirmada.

Controles recomendados

- Programa formal de Vulnerability Management.
- Escaneos periódicos.
- Gestión de parches.
- Hardening basado en CIS Benchmarks.
- Pentesting anual autorizado.
- Inventario actualizado de activos.

Marcos

- ISO 27001.
- NIST CSF.
- CIS Controls 4, 7 y 12.

Costo

Alto

Beneficio

Disminución de la superficie de ataque y fortalecimiento de la postura de ciberseguridad.

Riesgo R-011 – Falla de Backups y Recuperación de Información

Campo	Detalle
ID	R-011
Categoría	Continuidad del Negocio
Nivel de Riesgo	Crítico
Probabilidad	4
Impacto	5
Riesgo Inherente	20
Prioridad	Muy Alta
Responsable sugerido	Gerencia de Tecnología
Tiempo recomendado	90 días

Activos afectados

- Información corporativa.
- Servidores.
- Bases de datos.
- Aplicaciones críticas.
- Documentación administrativa.

Descripción

La indisponibilidad o falla de los mecanismos de respaldo puede impedir la recuperación de la información luego de un incidente de ciberseguridad, error humano o desastre físico.

Escenario

Se produce un incidente de ransomware y, durante la recuperación, se detecta que las copias de seguridad se encuentran dañadas o no pueden restaurarse correctamente.

Impacto para el negocio

- Pérdida permanente de información.
- Interrupción prolongada de operaciones.
- Pérdidas económicas.
- Incumplimiento de obligaciones legales.
- Daño reputacional.

Controles existentes (Supuestos)

- Copias de respaldo.
- Infraestructura tecnológica.

Brechas identificadas

- Pruebas de restauración no verificadas.
- Política de backups no evidenciada.
- Copias offline no verificadas.

Controles recomendados

- Estrategia **3-2-1** de respaldos.
- Backups inmutables.
- Pruebas trimestrales de restauración.
- Automatización del monitoreo.
- Procedimientos documentados.

Marcos de referencia

- ISO 27001
- ISO 22301

- NIST CSF – Recover
- CIS Controls 11

Costo estimado

Medio - Alto

Beneficio esperado

Garantizar la recuperación efectiva de la información crítica.

Riesgo R-012 – Amenaza Interna (Insider Threat)

Campo	Detalle
ID	R-012
Categoría	Humana
Nivel	Alto
Probabilidad	3
Impacto	5
Riesgo Inherente	15
Prioridad	Alta
Responsable	Recursos Humanos / Tecnología

Activos afectados

- Información confidencial.
- Sistemas administrativos.
- Infraestructura tecnológica.
- Documentación corporativa.

Descripción

Los colaboradores o terceros con acceso autorizado pueden comprometer activos críticos de forma intencional o accidental.

Escenario

Un colaborador utiliza privilegios autorizados para extraer información sensible o modificar registros críticos.

Impacto

- Robo de información.
- Fraude.
- Sabotaje.
- Daño reputacional.
- Riesgo legal.

Controles existentes

- Controles básicos de acceso.
- Supervisión jerárquica.

Brechas

- Revisión periódica de privilegios no verificada.
- Monitoreo de usuarios privilegiados no evidenciado.
- Programa de Insider Threat no evidenciado.

Controles recomendados

- Principio de mínimo privilegio.
- PAM (Privileged Access Management).
- Revisión trimestral de permisos.
- Auditoría de actividades privilegiadas.
- Programa de Insider Threat.

Marcos

- ISO 27001.
- NIST CSF.
- CIS Controls 6.

Costo

Medio

Beneficio

Reducción del riesgo asociado a usuarios privilegiados.

Riesgo R-013 – Incendio en Instalaciones Críticas

Campo	Detalle
ID	R-013
Categoría	Ambiental
Nivel	Alto
Probabilidad	2
Impacto	5
Riesgo Inherente	10
Prioridad	Alta
Responsable	Seguridad Física / Mantenimiento

Activos afectados

- Infraestructura edilicia.
- Data Room.
- Sistemas eléctricos.
- Equipamiento tecnológico.

Descripción

Un incendio podría comprometer simultáneamente infraestructura física, sistemas tecnológicos y continuidad del negocio.

Escenario

Un incidente eléctrico genera un incendio que afecta áreas técnicas y administrativas.

Impacto

- Evacuación.
- Interrupción total.
- Daños materiales.
- Pérdidas económicas.

Controles existentes

- Sistemas contra incendio.
- Generadores.
- Personal de seguridad.

Brechas

- Simulacros no verificados.
- Continuidad del negocio no evidenciada.
- Recuperación ante desastres no confirmada.

Controles recomendados

- Actualización del Plan de Emergencia.
- Simulacros periódicos.
- Protección de Data Room.
- Sensores inteligentes.
- Integración con BCP y DRP.

Marcos

- ISO 22301.
- ISO 31000.

Costo

Alto

Beneficio

Mayor resiliencia frente a eventos físicos.

Riesgo R-014 – Robo de Equipamiento Tecnológico

Campo	Detalle
ID	R-014
Categoría	Física
Nivel	Alto
Probabilidad	3
Impacto	4
Riesgo Inherente	12
Prioridad	Alta
Responsable	Seguridad Física

Activos afectados

- Notebooks.
- Equipos de escritorio.
- Equipamiento de red.
- Dispositivos móviles.
- Documentación física.

Descripción

El robo de equipamiento tecnológico puede generar pérdidas económicas, exposición de información y afectación operativa.

Escenario

Un equipo portátil con información corporativa es sustraído de una oficina administrativa.

Impacto

- Exposición de datos.
- Costos de reposición.
- Interrupción operativa.
- Riesgo reputacional.

Controles existentes

- Seguridad física.
- Videovigilancia.

Brechas

- Cifrado de dispositivos no verificado.
- Inventario permanente no confirmado.
- Gestión de activos móviles no evidenciada.

Controles recomendados

- Full Disk Encryption.
- Inventario automatizado.
- Etiquetado de activos.
- MDM para dispositivos móviles.
- Auditorías físicas.

Marcos

- ISO 27001.
- CIS Controls 1 y 3.

Costo

Medio

Beneficio

Protección de activos tecnológicos y reducción del riesgo de pérdida de información.

Riesgo R-015 – Error Humano en Procesos Críticos

Campo	Detalle
ID	R-015
Categoría	Operacional
Nivel	Alto
Probabilidad	4
Impacto	3
Riesgo Inherente	12
Prioridad	Alta
Responsable	Todas las Gerencias

Activos afectados

- Procesos administrativos.
- Información.
- Sistemas.
- Operaciones.

Descripción

El error humano continúa siendo una de las principales causas de incidentes de seguridad y fallas operativas.

Escenario

Un colaborador elimina información importante, configura incorrectamente un sistema o comparte información sensible por error.

Impacto

- Interrupción parcial de procesos.
- Pérdida de información.
- Demoras operativas.
- Incremento del riesgo de incidentes.

Controles existentes

- Procedimientos operativos.
- Supervisión.

Brechas

- Capacitación continua no evidenciada.
- Gestión del cambio no verificada.
- Lecciones aprendidas no documentadas.

Controles recomendados

- Programa anual de Security Awareness.
- Capacitación específica por área.
- Gestión formal del cambio.
- Simulaciones periódicas.
- Cultura de reporte de incidentes.

Marcos

- ISO 27001.
- NIST CSF.
- CIS Controls 14.

Costo

Bajo

Beneficio

Reducción sostenida del riesgo operacional y fortalecimiento de la cultura de seguridad.

10.16 Conclusiones del Capítulo

El análisis de los quince riesgos prioritarios permite identificar los escenarios con mayor potencial de afectar la continuidad operativa, la seguridad de la información y la capacidad de respuesta del centro comercial.

Los riesgos clasificados como **Críticos** se concentran principalmente en el ámbito tecnológico y de continuidad del negocio, destacándose el ransomware, el compromiso de credenciales, la gestión de vulnerabilidades y la recuperación de información. Estos escenarios requieren una atención prioritaria debido a su elevada probabilidad de ocurrencia y al impacto significativo que podrían generar sobre los procesos esenciales.

Por otra parte, los riesgos clasificados como **Altos** evidencian la importancia de fortalecer los controles relacionados con la gestión de proveedores, la seguridad física, la infraestructura, el estacionamiento, la protección de activos tecnológicos y la capacitación continua del personal.

En conjunto, este análisis proporciona una base objetiva para la definición de un plan de tratamiento de riesgos y un roadmap de implementación, orientado a mejorar progresivamente la postura de ciberseguridad y la resiliencia organizacional.

11. Heat Map Ejecutivo

11.1 Introducción

Este Heat Map representa gráficamente los riesgos del Risk Register según su probabilidad e impacto, para priorizar recursos y decisiones

La representación utilizada se encuentra alineada con las metodologías de gestión de riesgos recomendadas por ISO 31000:2018, ISO/IEC 27005:2022 y el NIST Cybersecurity Framework (CSF) 2.0.

11.2 Escala Utilizada

La clasificación de los riesgos fue realizada utilizando una matriz de cinco niveles para la probabilidad y cinco niveles para el impacto.

Escala de Probabilidad

Valor	Nivel
1	Muy Baja
2	Baja
3	Media
4	Alta
5	Muy Alta

Escala de Impacto

Valor	Nivel
1	Insignificante
2	Menor
3	Moderado
4	Alto
5	Crítico

11.3 Heat Map de Riesgos

Impacto ↓ / Probabilidad →	Muy Bajo	Bajo	Medio	Alto	Muy Alto
5 - Crítico				R-010 R-011	R-001
4 - Alto			R-004 R-005 R-006 R-007 R-009 R-014	R-002	
3 - Moderado				R-015	
2 - Menor					
1 - Insignificante					

Referencia

- Riesgo Bajo
- Riesgo Medio
- Riesgo Alto
- Riesgo Crítico

11.4 Distribución de Riesgos

Como resultado del análisis realizado, los quince riesgos priorizados fueron distribuidos de la siguiente manera:

Nivel de Riesgo	Cantidad	Porcentaje
Crítico	4	26,7 %
Alto	9	60,0 %
Medio	2	13,3 %
Bajo	0	0 %

Distribución por Categoría

Categoría	Riesgos
Tecnológicos	5
Humanos	3
Operacionales	3
Físicos	2
Continuidad del Negocio	1
Ambientales	1

11.5 Análisis Ejecutivo

El mapa de calor evidencia una concentración significativa de riesgos en los cuadrantes de **Alta Probabilidad** y **Alto Impacto**, especialmente aquellos relacionados con la infraestructura tecnológica, la protección de la información y la continuidad operativa.

Los riesgos clasificados como **Críticos** corresponden a escenarios que podrían comprometer simultáneamente múltiples procesos esenciales del negocio, afectando la disponibilidad de los servicios, la integridad de la información y la capacidad de recuperación de la organización.

Por su parte, los riesgos clasificados como **Altos** muestran una fuerte dependencia de controles preventivos asociados a la gestión de identidades, administración de vulnerabilidades, continuidad de servicios críticos, infraestructura tecnológica y seguridad física.

No se identificaron riesgos clasificados como **Bajos**, lo que resulta consistente con el perfil de un entorno comercial de alta complejidad operativa y elevada dependencia tecnológica.

11.6 Riesgos Prioritarios

A partir del análisis realizado, se recomienda otorgar prioridad inmediata a los siguientes escenarios:

Prioridad	Riesgo	Nivel
1	Ataque de Ransomware	Crítico
2	Compromiso de Credenciales	Crítico
3	Explotación de Vulnerabilidades	Crítico
4	Falla en Backups y Recuperación	Crítico
5	Fuga de Información	Alto
6	Ataque DDoS	Alto
7	Acceso Físico No Autorizado	Alto
8	Compromiso de Proveedores	Alto
9	Amenaza Interna	Alto
10	Falla del Sistema de Parking	Alto

11.7 Conclusiones

La concentración de riesgos en Alto y Crítico muestra la necesidad de fortalecer la seguridad y la resiliencia tecnológica. El siguiente capítulo presenta el Roadmap para reducir esta exposición.

12. Roadmap de Implementación

12.1 Introducción

Este Roadmap prioriza las iniciativas según la criticidad del riesgo, el impacto esperado y la relación costo-beneficio.

Las acciones propuestas se encuentran alineadas con los principios de mejora continua definidos por ISO/IEC 27001:2022, ISO 31000:2018, ISO 22301:2019, NIST Cybersecurity Framework 2.0 y CIS Controls v8.

El horizonte temporal se divide en tres etapas:

- Corto Plazo (0–90 días).
- Mediano Plazo (90–180 días).
- Largo Plazo (6–12 meses).

Esta planificación tiene como propósito facilitar una implementación gradual, permitiendo obtener mejoras tempranas sin afectar la operación diaria del centro comercial.

12.2 Fase I – Corto Plazo (0–90 días)

Objetivo

Reducir la exposición inmediata frente a los riesgos clasificados como **Críticos**, fortaleciendo los controles básicos de seguridad y continuidad del negocio.

Iniciativas Prioritarias

Prioridad	Iniciativa	Responsable	Beneficio Esperado
Muy Alta	Implementar MFA para accesos críticos	Tecnología	Reducción del riesgo de compromiso de cuentas
Muy Alta	Elaborar inventario formal de activos	Tecnología	Mayor visibilidad y control
Muy Alta	Revisar la estrategia de copias de seguridad	Tecnología	Mejora de la capacidad de recuperación

Muy Alta	Realizar pruebas de restauración de backups	Tecnología	Validación del proceso de recuperación
Alta	Iniciar programa de concientización en ciberseguridad	RRHH / Tecnología	Reducción del riesgo por error humano
Alta	Actualizar el registro de riesgos corporativos	Dirección	Mejor gobernanza
Alta	Definir responsables para cada activo crítico	Dirección	Mayor trazabilidad
Alta	Revisar accesos privilegiados	Tecnología	Reducción del riesgo interno
Alta	Actualizar procedimientos de respuesta a incidentes	Tecnología	Mejor capacidad de respuesta

Resultados Esperados

- Reducción del riesgo de ransomware.
- Disminución del riesgo de phishing.
- Mayor resiliencia operativa.
- Mejor visibilidad sobre los activos.
- Fortalecimiento de la gobernanza.

12.3 Fase II – Mediano Plazo (90–180 días)

Objetivo

Fortalecer los procesos de gestión de riesgos, mejorar la protección de la infraestructura tecnológica y consolidar mecanismos de continuidad operativa.

Iniciativas Prioritarias

Prioridad	Iniciativa	Responsable	Beneficio Esperado
Muy Alta	Implementar programa de Gestión de Vulnerabilidades	Tecnología	Disminución de la superficie de ataque
Muy Alta	Formalizar el Plan de Continuidad del Negocio (BCP)	Dirección	Mayor resiliencia
Muy Alta	Elaborar el Plan de Recuperación ante Desastres (DRP)	Tecnología	Recuperación más eficiente
Alta	Implementar segmentación de red	Tecnología	Limitación del movimiento lateral
Alta	Revisar la seguridad de proveedores críticos	Administración	Reducción del riesgo de terceros
Alta	Definir indicadores de ciberseguridad (KPIs)	Dirección	Seguimiento de desempeño
Alta	Implementar revisiones periódicas de privilegios	Tecnología	Control de accesos
Media	Mejorar la clasificación de la información	Administración	Protección de datos
Media	Documentar procedimientos operativos críticos	Operaciones	Estandarización de procesos

Resultados Esperados

- Mayor madurez en gestión de riesgos.
- Reducción del riesgo operacional.
- Mejor preparación ante incidentes.
- Fortalecimiento de la continuidad del negocio.

12.4 Fase III – Largo Plazo (6–12 meses)

Objetivo

Consolidar un modelo de mejora continua y elevar el nivel de madurez en ciberseguridad mediante la adopción de prácticas avanzadas de gobernanza, monitoreo y resiliencia.

Iniciativas Prioritarias

Prioridad	Iniciativa	Responsable	Beneficio Esperado
Muy Alta	Implementar monitoreo continuo (SOC interno o tercerizado)	Tecnología	Detección temprana de incidentes
Alta	Realizar ejercicios de simulación de incidentes	Tecnología / Seguridad	Mejora de la respuesta
Alta	Ejecutar auditorías internas periódicas	Auditoría / Dirección	Validación de controles
Alta	Evaluar madurez en ciberseguridad de forma anual	Dirección	Mejora continua
Alta	Revisar el programa de gestión de riesgos	Dirección	Actualización del contexto de riesgo
Media	Automatizar el inventario de activos	Tecnología	Mayor eficiencia operativa
Media	Fortalecer la gestión de terceros	Administración	Mayor control sobre proveedores
Media	Ejecutar campañas periódicas de phishing simulado	RRHH / Tecnología	Refuerzo de la cultura de seguridad
Media	Revisar políticas y procedimientos de seguridad	Dirección	Actualización normativa

Resultados Esperados

- Incremento del nivel de madurez en ciberseguridad.
- Reducción sostenida del riesgo residual.
- Consolidación de una cultura organizacional orientada a la seguridad.
- Fortalecimiento del cumplimiento de estándares internacionales.

12.5 Resumen Ejecutivo del Roadmap

Horizonte	Objetivo Principal	Prioridad
0–90 días	Reducir riesgos críticos y fortalecer controles básicos	Muy Alta
90–180 días	Implementar procesos de gestión y continuidad	Alta
6–12 meses	Consolidar la mejora continua y elevar la madurez	Estratégica

12.6 Beneficios Esperados

La ejecución gradual del Roadmap permitirá a la organización:

- Reducir la probabilidad de materialización de los riesgos críticos identificados.
- Mejorar la resiliencia frente a incidentes de ciberseguridad y eventos disruptivos.
- Fortalecer la gobernanza mediante la definición clara de responsabilidades y procesos.
- Incrementar la capacidad de detección, respuesta y recuperación ante incidentes.
- Optimizar la gestión de proveedores y la protección de los activos críticos.
- Alinear progresivamente la gestión de riesgos con estándares internacionales como ISO/IEC 27001, ISO 31000, ISO 22301, NIST CSF 2.0 y CIS Controls v8.

12.7 Conclusiones

Este Roadmap prioriza el mayor impacto con el menor esfuerzo inicial, y sienta las bases para las iniciativas de implementación inmediata del próximo capítulo.

13. Quick Wins – Iniciativas de Implementación Inmediata

13.1 Introducción

Estos son los "Quick Wins": acciones de bajo costo y alto impacto para reducir el riesgo mientras se avanza con el Roadmap.

Los Quick Wins aquí propuestos se basan en los riesgos identificados durante el Assessment y se encuentran alineados con las mejores prácticas definidas por ISO/IEC 27001:2022, ISO 31000:2018, NIST Cybersecurity Framework (CSF) 2.0 y CIS Controls v8.

13.2 Quick Wins Prioritarios

N.º	Iniciativa	Beneficio Principal	Complejidad	Costo
✓	Implementar Autenticación Multifactor (MFA)	Reduce el riesgo de compromiso de cuentas	Baja	Bajo
✓	Inventario completo de activos tecnológicos	Mayor visibilidad y control de activos	Baja	Bajo
✓	Clasificación de activos según criticidad	Mejora la gestión de riesgos	Baja	Bajo
✓	Revisión y validación de copias de seguridad	Aumenta la capacidad de recuperación	Baja	Bajo
✓	Capacitación inicial en Awareness	Reduce el riesgo de phishing e ingeniería social	Baja	Bajo
✓	Revisión de privilegios de usuarios	Limita accesos innecesarios	Baja	Bajo
✓	Actualización de políticas de contraseñas	Fortalece la autenticación	Baja	Bajo
✓	Inventario de proveedores críticos	Mejora la gestión de terceros	Baja	Bajo
✓	Documentación de procedimientos críticos	Incrementa la continuidad operativa	Baja	Bajo
✓	Registro centralizado de incidentes	Favorece la mejora continua	Baja	Bajo

13.3 Acciones Recomendadas

13.3.1 Implementación de Autenticación Multifactor (MFA)

La incorporación de mecanismos de autenticación multifactor constituye una de las medidas más efectivas para reducir el riesgo de compromiso de cuentas corporativas.

Beneficios

- Protección frente a robo de credenciales.
- Mitigación de ataques de phishing.
- Mayor seguridad en accesos remotos.
- Cumplimiento de buenas prácticas internacionales.

13.3.2 Inventario Formal de Activos

Mantener un inventario actualizado de activos físicos, tecnológicos, de información y servicios críticos permite mejorar significativamente la gestión de riesgos y facilitar la toma de decisiones.

Beneficios

- Identificación de activos críticos.
- Mejor gestión de vulnerabilidades.
- Priorización de inversiones.
- Mayor control operativo.

13.3.3 Programa Inicial de Security Awareness

La concientización del personal constituye uno de los controles preventivos con mejor relación costo-beneficio.

Acciones sugeridas

- Capacitación introductoria.
- Simulaciones de phishing.
- Boletines mensuales.
- Material gráfico.
- Campañas de comunicación interna.

Beneficios

- Reducción del error humano.
- Incremento de la cultura organizacional.
- Disminución del riesgo de ingeniería social.

13.3.4 Revisión de la Estrategia de Backups

Verificar periódicamente la existencia, integridad y capacidad de restauración de las copias de seguridad permite garantizar la recuperación de información ante incidentes.

Acciones sugeridas

- Revisar frecuencia de respaldos.
- Validar restauraciones.
- Documentar procedimientos.
- Implementar estrategia 3-2-1.

13.3.5 Gestión Inicial de Proveedores

La dependencia de terceros hace recomendable implementar controles mínimos sobre los proveedores considerados críticos para la operación.

Acciones sugeridas

- Identificar proveedores críticos.
- Revisar contratos.
- Verificar acuerdos de nivel de servicio (SLA).
- Incorporar requisitos básicos de seguridad.

13.3.6 Clasificación de Activos

La clasificación de los activos según su criticidad facilita la priorización de controles y la asignación eficiente de recursos.

Criterios sugeridos

- Criticidad para el negocio.
- Confidencialidad.
- Integridad.
- Disponibilidad.
- Impacto operacional.

13.3.7 Actualización de la Política de Contraseñas

La revisión de las políticas de autenticación constituye una medida sencilla con un impacto directo sobre la reducción del riesgo de acceso no autorizado.

Recomendaciones

- Longitud mínima de 14 caracteres.
- Uso de frases de paso (Passphrases).
- Eliminación del cambio periódico sin justificación.
- Prohibición de contraseñas reutilizadas.
- Integración con MFA.

13.3.8 Registro Centralizado de Incidentes

Disponer de un procedimiento formal para registrar, clasificar y analizar incidentes permite mejorar la capacidad de respuesta y generar información útil para la gestión de riesgos.

Beneficios

- Identificación de tendencias.
- Mejora continua.
- Lecciones aprendidas.
- Reportes ejecutivos.

13.4 Beneficios Esperados

La implementación de las iniciativas propuestas permitirá obtener resultados visibles en un período reducido de tiempo, fortaleciendo los controles preventivos y mejorando la postura general de ciberseguridad.

Entre los principales beneficios esperados se destacan:

- Reducción de la probabilidad de materialización de riesgos críticos.
- Incremento de la capacidad de detección y respuesta ante incidentes.
- Mejora en la protección de la información crítica.
- Optimización de la gestión de activos y proveedores.
- Fortalecimiento de la cultura organizacional en materia de seguridad.
- Incremento del nivel de madurez en Gobernanza, Gestión de Riesgos y Cumplimiento (GRC).

13.5 Resumen Ejecutivo de Quick Wins

Quick Win	Impacto	Esfuerzo	Prioridad
Implementar MFA	Alto	Bajo	Muy Alta
Inventario de activos	Alto	Bajo	Muy Alta
Clasificación de activos	Alto	Bajo	Alta
Programa de Awareness	Alto	Bajo	Muy Alta
Revisión de Backups	Alto	Bajo	Muy Alta
Gestión de Proveedores	Medio	Bajo	Alta
Política de Contraseñas	Alto	Bajo	Alta
Registro de Incidentes	Medio	Bajo	Alta
Revisión de Privilegios	Alto	Bajo	Muy Alta
Documentación de Procedimientos	Medio	Bajo	Media

13.6 Conclusiones

Los Quick Wins ofrecen mejoras tangibles sin grandes inversiones, y sientan la base para el Roadmap de mediano y largo plazo.

14. Conclusión General

El presente Assessment identificó 25 riesgos operativos y de ciberseguridad para un entorno de shopping center, de los cuales el 72% se clasifica como Alto o Crítico. Los escenarios de mayor exposición —ransomware, compromiso de credenciales, explotación de vulnerabilidades y fallas de backup— comparten una causa raíz común: la ausencia evidenciada de controles preventivos básicos (MFA, gestión de parches, validación de restauraciones) frente a una alta dependencia tecnológica de la operación diaria. El Roadmap propuesto permite abordar esta exposición en tres fases (0–90 días, 90–180 días y 6–12 meses), priorizando las iniciativas de mayor relación costo-beneficio a través de los Quick Wins identificados en el Capítulo 13. Este ejercicio demuestra cómo la aplicación de metodologías de GRC alineadas a ISO/IEC 27001:2022, ISO 31000:2018, NIST CSF 2.0 y CIS Controls v8 permite construir una visión priorizada y accionable del riesgo, incluso en un análisis de alcance limitado y basado en información pública.